

TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN, ĐHQG-HCM
KHOA MẠNG MÁY TÍNH VÀ TRUYỀN THÔNG



ĐỒ ÁN MÔN HỌC

**ĐỀ TÀI: Triển khai CIS Benchmark trên hệ thống
Windows Server 2022**

Môn học: NT542 - Lập trình kịch bản tự động hóa cho quản trị và bảo mật mạng

Giảng viên hướng dẫn: ThS. Văn Thiên Luân

Thực hiện bởi nhóm 7, bao gồm:

1. Lê Trung Kiên	23520797	Trưởng nhóm
2. Nguyễn Tiến Phát	23521147	Thành viên
3. Nguyễn Thị Như Trang	23521628	Thành viên
4. Trần Nguyễn Phú Thuận	23521554	Thành viên

Thời gian thực hiện: 26/04/2025 – 18/05/2026

GitHub: [kudoshinichi2k5/NT542.Q22-Project](https://github.com/kudoshinichi2k5/NT542.Q22-Project)

LỜI CẢM ƠN

Trong quá trình thực hiện đồ án “*Triển khai CIS Benchmark trên hệ thống Windows Server 2022*”, nhóm đã nhận được rất nhiều sự hỗ trợ, hướng dẫn từ các thành viên trong nhóm cũng như thầy hướng dẫn lớp.

Nhóm xin gửi lời tri ân đến quý thầy cô của khoa đã tận tình giảng dạy, truyền đạt những kiến thức nền tảng và chuyên môn quan trọng trong suốt quá trình học tập. Những kiến thức về hệ thống mạng, bảo mật thông tin, Windows Server, PowerShell và quản trị hệ thống đã giúp nhóm có đủ nền tảng để hoàn thành đồ án này. Mặc dù đã cố gắng hoàn thiện đề tài trong khả năng tốt nhất, tuy nhiên dự án chắc chắn vẫn còn những thiếu sót nhất định. Nhóm rất mong nhận được những ý kiến đóng góp từ quý thầy cô và các bạn để đề tài được hoàn thiện hơn trong tương lai.

Nhóm xin gửi lời tri ân đến quý thầy cô!

MỤC LỤC

DANH SÁCH HÌNH	6
DANH SÁCH BẢNG	7
Chương I. TỔNG QUAN	8
1.1. Đặt vấn đề	8
1.2. Mục tiêu đề tài	9
Chương II. CƠ SỞ LÝ THUYẾT VÀ KIẾN TRÚC HỆ THỐNG	11
2.1. Tổng quan CIS	11
2.2. Tổng quan Windows Server	11
2.3. Công cụ sử dụng	11
2.3.1. Wazuh	12
2.3.2. Windows Powershell ISE	13
2.3.3. HardeningKitty	13
2.3.4. Ansible	14
2.4. Mô hình kiến trúc hệ thống	14
Chương III. PHÂN TÍCH CÁC TIÊU CHUẨN BẢO MẬT	18
3.1. Identity and Access Control	18
3.1.1. Chính sách mật khẩu (Password Policy)	18
3.1.2. Chính sách khóa tài khoản (Account Lockout Policy)	20
3.1.3. Gán quyền người dùng (User Rights Assignment)	21
3.1.4. Các tùy chọn bảo mật – Tài khoản (Security Options – Accounts)	25
3.2. Network and Services Security	27
3.2.1. Network Security and Access	27
3.2.2. Windows Firewall	32
3.2.3. Services, Printers and RDP	34

3.3. Auditing and Monitoring	36
3.3.1. Audit	36
3.3.2. Event Log Service	39
3.4. System Hardening and Antimalware	41
3.4.1. Microsoft Defender Antivirus	42
3.4.2. MS Security Guide, MSS (Legacy) và UAC	43
Chương IV. PHƯƠNG PHÁP TRIỂN KHAI	44
4.1. Manual configuration	44
4.2. Tự động hóa cấu hình	48
4.2.1 Tự động hóa sử dụng PowerShell Scripting	48
4.2.2 Tự động hóa tập trung với Ansible	48
Chương V. TOOL KIỂM ĐỊNH VÀ GIÁM SÁT TẬP TRUNG	51
5.1. HardeningKitty	51
5.1.1. Tích hợp vào hệ thống	51
5.2. Wazuh	51
5.2.1. Tích hợp vào hệ thống	51
5.2.2. Kết quả triển khai Wazuh bằng Ansible	52
Chương VI. TỔNG KẾT	55
6.1. Kết quả	55
6.1.1 Kết quả các cấu hình	55
6.1.2 Kết quả đánh giá bổ sung bằng HardeningKitty	58
6.1.3. Kết quả giám sát với Wazuh	60
6.2. Hạn chế và hướng phát triển	61
6.2.1 Hạn chế hiện tại	61
6.2.2 Hướng phát triển	62

6.3.	Kết luận	62
	BẢNG PHÂN CÔNG	63
	NGUỒN THAM KHẢO	64

DANH SÁCH HÌNH

Hình 1. Icon WAZUH	12
Hình 2. Giao diện Windows Powershell ISE	13
Hình 3. Icon HardeningKitty	13
Hình 4. Icon Ansible	14
Hình 5. Sơ đồ hệ thống	16
Hình 6. Giao diện Registry Editor hiển thị cấu hình dịch vụ Print Spooler	45
Hình 7. Cấu hình dịch vụ Print Spooler trong Registry Editor	46
Hình 8. Giao diện Registry Editor hiển thị cấu hình dịch vụ Print Spooler sau điều chỉnh	47
Hình 9. Pipeline tự động hóa	49
Hình 10. Cấu hình các biến môi trường sử dụng Ansible	50
Hình 11. Kết quả triển khai Wazuh Manager và Wazuh Agent sử dụng Ansible	53
Hình 12. Giao diện chính của Wazuh	53
Hình 13. Giao diện giám sát tập trung	54
Hình 14. Giao diện giám sát đơn máy	54
Hình 15. Kết quả post audit nhóm Identity và Access Control	55
Hình 16. Kết quả Post-Audit nhóm Network Services Security	56
Hình 17. Kết quả Post-Audit nhóm Auditing và Monitoring	57
Hình 18. Kết quả post-audit System Hardening & Antimalware	58
Hình 19. Kết quả kiểm định HardeningKitty trên máy chủ dc01	59
Hình 20. Kết quả kiểm định HardeningKitty trên máy chủ member01	59
Hình 21. Trích đoạn file CSV chi tiết của HardeningKitty trên máy chủ member01 ..	59
Hình 22. Kết quả giám sát trên máy dc01	60
Hình 23. Kết quả giám sát trên máy member01	61
Hình 24. Kết quả giám sát trên máy fs01	61

DANH SÁCH BẢNG

Bảng 1: Thành phần hệ thống	16
Bảng 2. Danh sách các chính sách mật khẩu	18
Bảng 3. Danh sách các chính sách khóa tài khoản	20
Bảng 4. Danh sách các chính sách Gán quyền người dùng	24
Bảng 5. Danh sách các chính sách Bảo mật – Tài khoản	25
Bảng 6. Danh sách các chính sách Network Security and Access	31
Bảng 7. Danh sách các chính sách Windows Firewall	33
Bảng 8. Danh sách các chính sách Services, Printers and RDP	36
Bảng 9. Danh sách các chính sách Audit	38
Bảng 10. Danh sách các chính sách Event Log Service	40

Chương I. TỔNG QUAN

1.1. Đặt vấn đề

Trong kỷ nguyên số hóa, các tổ chức doanh nghiệp ngày càng phụ thuộc vào hệ thống máy chủ để vận hành các dịch vụ cốt lõi như quản lý danh tính, lưu trữ dữ liệu, chia sẻ tập tin và triển khai ứng dụng. Microsoft Windows Server 2022 là một trong những hệ điều hành máy chủ phổ biến nhất, đặc biệt trong các môi trường sử dụng Active Directory và các dịch vụ đám mây kết hợp (hybrid). Tuy nhiên, cùng với sự phổ biến đó là nguy cơ an toàn thông tin ngày càng gia tăng, đặc biệt là các cuộc tấn công khai thác lỗ hổng cấu hình (misconfiguration) và các dịch vụ mạng không được bảo vệ đúng mức.

Một trong những ví dụ điển hình là lỗ hổng PrintNightmare (CVE-2021-34527) liên quan đến dịch vụ Print Spooler trên Windows Server, cho phép kẻ tấn công thực thi mã từ xa với đặc quyền SYSTEM. Chính vì vậy, việc thiết lập một chuẩn cấu hình bảo mật (security baseline) vững chắc là yêu cầu bắt buộc đối với bất kỳ hệ thống máy chủ nào trong môi trường doanh nghiệp.

Trên thế giới, CIS Benchmarks do tổ chức phi lợi nhuận Center for Internet Security (CIS) phát triển được công nhận rộng rãi như một bộ khuyến nghị thực hành tốt nhất để bảo mật hệ thống CNTT. Tài liệu “CIS Microsoft Windows Server 2022 Benchmark v5.0.0” cung cấp hơn 1.100 khuyến nghị chi tiết, phân chia thành các cấp độ (Level 1, Level 2) và áp dụng riêng cho Domain Controller và Member Server. Các khuyến nghị này bao gồm nhiều lĩnh vực quan trọng như: chính sách mật khẩu (Password Policy – mục 1.1), khóa tài khoản (Account Lockout Policy – mục 1.2), gán quyền người dùng (User Rights Assignment – mục 2.2), tùy chọn bảo mật mạng (Network Security Options – mục 2.3), cấu hình tường lửa Windows Defender (mục 9), chính sách kiểm tra nâng cao (Advanced Audit Policy – mục 17), và vô số thiết lập khác trong Administrative Templates (mục 18).

Tuy nhiên, việc áp dụng thủ công hàng trăm khuyến nghị như vậy trên nhiều máy chủ là một bài toán vô cùng khó khăn, tốn thời gian và dễ xảy ra sai sót. Các tổ chức thường gặp phải các thách thức sau:

- Thiếu chuẩn thống nhất: Mỗi quản trị viên có thể hiểu và thực hiện cấu hình theo cách riêng, dẫn đến sự không đồng nhất về bảo mật.
- Khó kiểm soát và kiểm định: Không có công cụ tự động để đánh giá mức độ tuân thủ (compliance) của các máy chủ so với chuẩn CIS.
- Không có giám sát tập trung: Khi cấu hình bị thay đổi do tác nhân xấu hoặc lỗi con người, hệ thống quản trị thiếu khả năng phát hiện và cảnh báo kịp thời.

Xuất phát từ những vấn đề trên, đồ án này được thực hiện nhằm xây dựng một giải pháp tự động hóa việc áp chuẩn bảo mật CIS Benchmark cho Windows Server 2022, đồng thời tích hợp với hệ thống giám sát tập trung Wazuh để kiểm tra, đánh giá và cảnh báo sự tuân thủ một cách liên tục. Giải pháp hứa hẹn giúp các tổ chức giảm thiểu rủi ro bảo mật, tiết kiệm thời gian quản trị và nâng cao khả năng phòng chống tấn công mạng.

1.2. Mục tiêu đề tài

Đề tài hướng đến các mục tiêu cụ thể sau đây, được tổ chức thành bốn nhóm chính:

a) Phân tích và lựa chọn các khuyến nghị phù hợp

- Phân tích chi tiết các khuyến nghị trong tài liệu CIS Microsoft Windows Server 2022 Benchmark v5.0.0, tập trung vào các nhóm chính: Account Policies, Local Policies (User Rights Assignment và Security Options), Windows Defender Firewall, Advanced Audit Policy, và các thiết lập trong Administrative Templates (Computer Configuration).
- Dựa trên hồ sơ (profile) Level 1 – Member Server và Level 1 – Domain Controller, lựa chọn các khuyến nghị có tính thực tiễn cao, không gây ảnh hưởng lớn đến hoạt động của hệ thống (theo đánh giá Impact trong tài liệu).
- Giải thích cơ sở lý thuyết của từng khuyến nghị thông qua các phần Description, Rationale và Impact có trong CIS Benchmark.

b) Xây dựng giải pháp tự động hóa cấu hình

- Sử dụng ngôn ngữ kịch bản PowerShell và môi trường PowerShell ISE để viết các script tự động hóa việc cài đặt các tham số bảo mật.

- Kết hợp với công cụ quản lý cấu hình Ansible để triển khai đồng loạt các cấu hình đến nhiều máy chủ Windows Server 2022 (Member Server và Domain Controller) trong môi trường mạng.
- Đảm bảo giải pháp có thể tái sử dụng, dễ dàng điều chỉnh khi có phiên bản mới của CIS Benchmark hoặc khi có thay đổi về hạ tầng.

c) Xây dựng hệ thống kiểm định và giám sát tập trung

- Sử dụng công cụ HardeningKitty để thực hiện đánh giá mức độ tuân thủ (compliance assessment) trên các máy chủ sau khi đã áp dụng cấu hình.
- Triển khai hệ thống Wazuh (bao gồm Wazuh Indexer, Wazuh Server và Wazuh Agent trên các máy chủ Windows) để:
- Thu thập nhật ký bảo mật (Security Event Log) và nhật ký hệ thống.
- Phân tích các sự kiện liên quan đến chính sách kiểm tra nâng cao (Advanced Audit Policy) đã được cấu hình theo CIS Benchmark, ví dụ: Audit Logon (ID 4624, 4625), Audit Account Lockout (ID 4625), Audit Sensitive Privilege Use (ID 4672), v.v.
- Tạo cảnh báo (alerts) khi phát hiện các thay đổi cấu hình quan trọng hoặc các hành vi bất thường vi phạm chuẩn CIS.
- Xây dựng bảng điều khiển (dashboard) hiển thị tỷ lệ tuân thủ theo thời gian thực.

d) Đánh giá và kết luận

- So sánh trạng thái bảo mật của hệ thống trước và sau khi áp dụng giải pháp, sử dụng các chỉ số định lượng như: số lượng khuyến nghị đạt yêu cầu, tỷ lệ % tuân thủ tổng thể.
- Đánh giá tác động về hiệu năng dựa trên các cảnh báo từ Impact của các khuyến nghị, ví dụ như ảnh hưởng của SMB signing đến hiệu suất truyền tải tập tin.
- Đưa ra các khuyến nghị về lộ trình áp dụng, các ngoại lệ (exceptions) có thể cần thiết cho một số dịch vụ đặc thù (ví dụ: cho phép IIS_IUSRS có quyền Impersonate a client after authentication với máy chủ web).

Chương II. CƠ SỞ LÝ THUYẾT VÀ KIẾN TRÚC HỆ THỐNG

2.1. Tổng quan CIS

CIS (Center for Internet Security): là một tổ chức phi lợi nhuận được thành lập từ năm 2000 với sứ mệnh tạo nên một thế giới số an toàn hơn. Sản phẩm nổi bật nhất của họ là CIS Benchmarks, một tập hợp các tiêu chuẩn bảo mật toàn diện và hoàn toàn miễn phí. Bộ tiêu chuẩn này cung cấp các hướng dẫn chi tiết nhất về cách cấu hình hệ thống và phần mềm sao cho an toàn, giúp các cá nhân, tổ chức và doanh nghiệp giảm thiểu tối đa rủi ro bị tấn công mạng và tuân thủ các quy định bảo mật. Hiện nay CIS Benchmarks là một trong những giải pháp phòng thủ được sử dụng rộng rãi nhất trên toàn cầu [1].

CIS Microsoft Windows Server 2022 Benchmark v5.0.0: là 1 tài liệu hướng dẫn kỹ thuật chuyên sâu dùng để thiết lập trạng thái cấu hình bảo mật an toàn cho hệ điều hành Windows Server 2022. Tài liệu được thiết kế dành riêng cho các hệ thống tham gia Active Directory domain và được quản lý tập trung bằng Group Policy Manager.

2.2. Tổng quan Windows Server

Windows Server 2022 là phiên bản chính thức thứ 13 của hệ điều hành máy chủ thuộc dòng Windows NT do Microsoft phát triển. Phiên bản này mang đến nhiều cải tiến vượt trội tập trung vào 3 yếu tố chính:

- + Bảo mật đa lớp: Tăng cường an toàn với cấu trúc Secured-core server, mã hóa AES-256 cho lưu lượng SMB, giao thức SMB qua QUIC và DNS qua HTTPS.
- + Lưu trữ và Hybrid cloud: Tích hợp sâu rộng các khả năng đám mây lai với nền tảng Microsoft Azure và cải thiện tính năng di chuyển bộ lưu trữ.
- + Đa dạng phiên bản: Hệ thống cung cấp các phiên bản phù hợp với nhiều quy mô như Essentials, Standard, Datacenter và Azure Datacenter [2].

2.3. Công cụ sử dụng

2.3.1. Wazuh



Hình 1. Icon WAZUH

Wazuh là nền tảng an ninh mạng mã nguồn mở hợp nhất hai công nghệ XDR và SIEM vào một giải pháp duy nhất.

Cấu trúc chính của Wazuh bao gồm:

- + Các thành phần trung tâm (Wazuh indexer, server, dashboard): Chịu trách nhiệm quản lý, phân tích dữ liệu, lưu trữ cảnh báo và cung cấp giao diện hiển thị trực quan
- + Wazuh Agent: Các tác nhân đa nền tảng cài trực tiếp trên thiết bị (Windows, Linux, macOS, ...) để thu thập dữ liệu, ngăn ngừa và phản hồi trực tiếp

Chức năng: liên tục giám sát hệ thống mạng, thiết bị đầu cuối, đám mây và container để tự động phát hiện lỗ hổng/mã độc, phản hồi sự cố và giúp tổ chức đáp ứng các quy định tuân thủ bảo mật [3].

2.3.2. Windows Powershell ISE

```

Administrator: Windows PowerShell ISE
File Edit View Tools Debug Add-ons Help

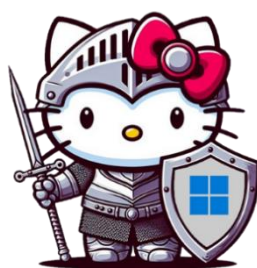
CIS-WinServer2022-Audit.ps1 CIS-WinServer2022-Remediation.ps1 CIS-Orchestrator.ps1*

19 Write-Host "BAT DAU QUET (AUDIT) HE THONG THEO CHUAN CIS BENCHMARK V5.0.0" -ForegroundColor White -BackgroundColor DarkBlue
20 Write-Host "Thoi gian bat dau : $TimestampDisplay" -ForegroundColor Cyan
21 Write-Host "He dieu hanh : $OSInfo" -ForegroundColor Cyan
22 Write-Host "=====n" -ForegroundColor Cyan
23
24 # 3. DEFINE AUDIT RULES (Intentionally keeping your exact rules)
25 $AuditRules = @(...)
26
27 # 4. THUC HIEN KIEM TRA (AUDIT LOGIC)
28 $Results = @()
29
30 # Cấu hình hiển thị console (cắt gọn text để khỏi vỡ dòng)
31 $fmt = "{0,-10} | {1,-35} | {2,-8} | {3,-15} | {4,-6}"
32 Write-Host ($fmt -f "CIS ID", "Registry Key", "Expected", "Current", "Status")
33 Write-Host ("-" * 85)
34
35 foreach ($Rule in $AuditRules) {
36     $status = "Fail"
37     $strVal = "Not Configured"
38     try {
39         $val = Get-ItemPropertyValue -Path $Rule.Path -Name $Rule.Key -ErrorAction Stop
40         $strVal = [string]$val
41     } catch {
42         # Xử lý logic ngoại lệ
43         if ([string]$val -eq [string]$Rule.Expected) {
44             $status = "Pass"
45         }
46     }
47     $Results += $Rule
48 }
49
50 [HTML Report] : C:\CIS-Automation\Reports\HTML\CIS-Audit-20260505_094057.html
51 [JSON Data] : C:\CIS-Automation\Reports\JSON\CIS-Audit-20260505_094057.json
52
53 [5/5] Đang tạo Báo cáo Auto-Healing (HTML)...
54 [?] DA KHOAI PHUC THANH CONG: 0 /
55 [!] CO 1 MUC XONG THE KHOAI PHUC TUONG!
56 [*] Báo cáo Auto-Healing lưu tại: C:\CIS-Automation\Reports\HTML\CIS-AutoHealing-20260505_094040.html
57
58 Transcript stopped, output file is C:\CIS-Automation\Reports\orchestrator-debug.log
59 PS C:\CIS-Automation> -NoProfile -NonInteractive -ExecutionPolicy Bypass -Command "New-Item -Path 'C:\CIS-Automation\test-ok.txt' -ItemType File -Force"
    
```

Hình 2. Giao diện Windows Powershell ISE

Windows Powershell ISE (Integrated Scripting Environment) là môi trường kịch bản tích hợp có giao diện đồ họa, cho phép người dùng chạy lệnh, viết, kiểm tra và gỡ lỗi các đoạn mã script trong một giao diện duy nhất [4].

2.3.3. HardeningKitty



Hình 3. Icon HardeningKitty

HardeningKitty là một module và framework mã nguồn mở dựa trên Powershell, được thiết kế chuyên biệt để tự động hóa việc đánh giá và tăng cường bảo mật cho các hệ thống Windows dựa trên các tiêu chuẩn bảo mật.

Hệ thống hỗ trợ lên tới hơn 40 danh sách kiểm tra cấu hình, bao phủ hàng loạt các khung tiêu chuẩn bảo mật uy tín như Microsoft Security Baseline, CIS Benchmarks,

DoD STIGs, ... Hệ điều hành được hỗ trợ trải dài từ Windows 10, Windows 11, các phiên bản Windows Server (từ 2012 R2 đến 2022) [5].

2.3.4. Ansible



Hình 4. Icon Ansible

Ansible là một nền tảng tự động hóa mã nguồn mở giúp quản trị viên đơn giản hóa các tác vụ như triển khai ứng dụng, cấu hình máy chủ và quản lý thiết bị mạng một cách nhanh chóng và hiệu quả. Nền tảng này sử dụng ngôn ngữ lập trình khai báo đơn giản là YAML để mô tả các quy trình triển khai cơ sở hạ tầng thông qua các tệp kịch bản được gọi là Playbook.

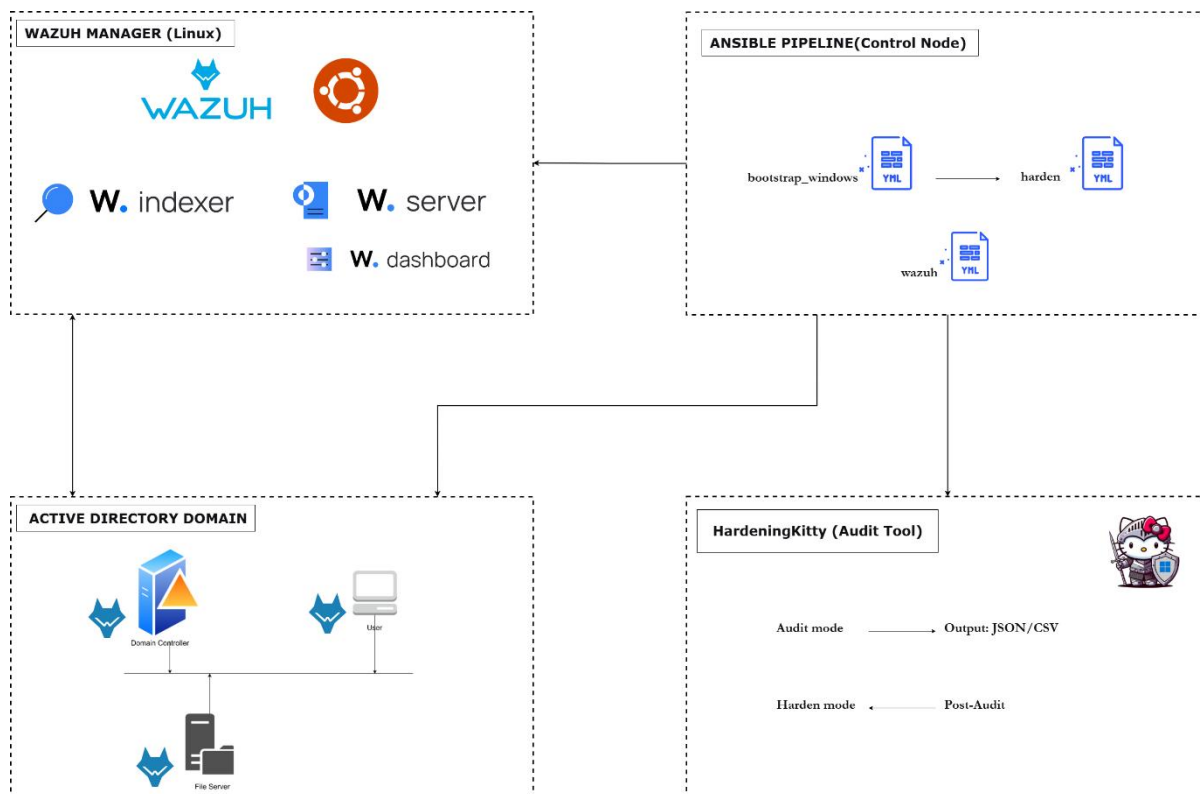
Điểm nổi bật lớn nhất của Ansible là sử dụng kiến trúc không máy khách, nghĩa là người dùng không cần phải cài đặt bất kỳ tác nhân (agent) hay daemon nào trên các máy chủ mục tiêu. Nhờ đặc điểm gọn nhẹ này kết hợp với khả năng mở rộng cực tốt, Ansible có thể dễ dàng quản lý tự động hóa từ một máy chủ đơn lẻ cho đến hàng nghìn máy chủ trải dài trên nhiều trung tâm dữ liệu [6].

2.4. Mô hình kiến trúc hệ thống

Dựa trên các thành phần đã trình bày ở các mục 2.1, 2.2, 2.3, đồ án xây dựng một **mô hình kiến trúc hệ thống tập trung** nhằm tự động hóa việc áp dụng chuẩn bảo mật CIS Benchmark cho Windows Server 2022, đồng thời giám sát liên tục trạng thái tuân thủ. Mô hình bao gồm ba khối chính: (1) cụm máy chủ Windows tham gia Active Directory, (2) máy chủ giám sát Wazuh (Linux), và (3) pipeline tự động hóa dựa trên Ansible và HardeningKitty.

Vai trò	Hostname	Hệ điều hành	Mô tả chức năng
Domain Controller	DC-01	Windows Server 2022	Quản lý xác thực người dùng, cấp phát chính sách nhóm (GPO), lưu trữ cơ sở dữ liệu Active Directory.
File Server	FS-01	Windows Server 2022	Cung cấp dịch vụ chia sẻ tập tin (SMB), đóng vai trò là member server trong domain.
Trạm người dùng	USER-01	Windows 10/11 (hoặc Windows Server 2022)	Mô phỏng máy trạm kết nối domain, thực hiện các tác vụ nghiệp vụ thông thường.
Wazuh Manager	log01	Ubuntu 22.04 (Linux)	Chạy bộ ba Wazuh Indexer, Server, Dashboard; thu thập log, thực hiện SCA (Security Configuration Assessment) theo CIS Benchmark, phát hiện lỗ hổng và hiển thị cảnh báo MITRE.
Ansible Control Node	(Linux)	Linux / Windows WSL	Nơi lưu trữ các playbook (bootstrap_windows.yml, pipeline.yml, wazuh.yml) và điều phối việc cấu hình từ xa qua WinRM.
HardeningKitty	(chạy liên hoạt)	Windows / PowerShell	Công cụ kiểm tra độc lập, được sử dụng để đánh giá mức độ tuân thủ trước và sau khi áp dụng cấu hình.

Bảng 1: Thành phần hệ thống



Hình 5. Sơ đồ hệ thống

Quy trình thực hiện được thiết kế theo vòng lặp **Audit** → **Remediate** → **Post-Audit** → **Report**, cụ thể như sau:

1. Chuẩn bị và cài đặt Agent

Ansible playbook `bootstrap_windows.yml` thực hiện:

- Gia nhập các máy Windows vào domain (nếu chưa có).
- Cài đặt Wazuh agent trên DC-01, FS-01, USER-01.
- Cấu hình agent gửi log sự kiện, thông tin cấu hình (inventory) về Wazuh Manager.

2. Đánh giá ban đầu (Audit)

- **Wazuh SCA** (Security Configuration Assessment) sử dụng file cấu hình CIS Benchmark v5.0.0 để quét các máy chủ Windows và xác định những mục chưa tuân thủ.

- **HardeningKitty** được chạy song song (hoặc thay thế) để kiểm tra chi tiết các nhóm chính sách phức tạp (User Rights Assignment, Security Options, ...).

3. Tự động khắc phục (Remediate)

- Ansible playbook pipeline.yml (hoặc wazuh.yml) đọc kết quả từ bước audit, tự động sinh các tác vụ cấu hình dựa trên khuyến nghị CIS.
- Các thiết lập được áp dụng bao gồm: chính sách mật khẩu, khóa tài khoản, gán quyền người dùng, tường lửa Windows Defender, chính sách kiểm tra nâng cao, v.v.
- Việc áp dụng được thực hiện từ xa qua WinRM mà không cần cài agent đặc biệt trên máy mục tiêu (nhờ kiến trúc không máy khách của Ansible).

4. Kiểm tra lại (Post- Audit)

- Chạy lại Wazuh SCA và HardeningKitty để xác nhận các cấu hình đã được sửa đúng theo chuẩn.
- Nếu vẫn còn sai lệch, hệ thống ghi nhận vào log và có thể kích hoạt lại quy trình remediate (tối đa 3 lần).

5. Giám sát liên tục (Continuous Monitoring)

- Wazuh agent liên tục gửi các sự kiện an ninh (logon/logoff, thay đổi quyền, tường lửa, ...) và kết quả SCA về Wazuh Manager.
- Wazuh Dashboard hiển thị:
 - o **Tỷ lệ tuân thủ** theo thời gian thực.
 - o **Các lỗ hổng** (vulnerabilities) phát hiện trên từng máy.
 - o **Ánh xạ với khung MITRE ATT&CK** để phân tích tấn công.

6. Tổng hợp báo cáo (Report)

Xuất báo cáo từ Wazuh Dashboard (định dạng PDF/CSV) phục vụ công tác kiểm định, lưu trữ và cải tiến liên tục.

Chương III. PHÂN TÍCH CÁC TIÊU CHUẨN BẢO MẬT

3.1. Identity and Access Control

Phần này tập trung vào việc bảo vệ định danh người dùng và quản lý chặt chẽ các quyền hạn đặc quyền trên hệ thống Windows Server. Các chính sách được chia thành ba nhóm chính: Chính sách tài khoản (Account Policies), Gán quyền người dùng (User Rights Assignment) và các tùy chọn bảo mật liên quan đến tài khoản (Security Options – Accounts). Việc áp dụng đúng các cấu hình này giúp ngăn chặn các cuộc tấn công vét cạn (brute-force), leo thang đặc quyền và khai thác tài khoản mặc định.

3.1.1. Chính sách mật khẩu (Password Policy)

CIS ID	Tên chính sách	Giá trị yêu cầu
1.1.1	Enforce password history	24 or more password(s)
1.1.2	Maximum password age	365 or fewer days, but not 0
1.1.3	Minimum password age	1 or more day(s)
1.1.4	Minimum password length	14 or more character(s)
1.1.5	Password must meet complexity requirements	Enabled
1.1.6	Relax minimum password length limits	Enabled
1.1.7	Store passwords using reversible encryption	Disabled

Bảng 2. Danh sách các chính sách mật khẩu

a) Ý nghĩa bảo mật

- **Enforce password history (1.1.1):** Ngăn người dùng tái sử dụng cùng một mật khẩu trong một số lần thay đổi gần nhất (tối thiểu 24 lần). Kết hợp với *Minimum password age* sẽ hạn chế việc người dùng thay đổi mật khẩu liên tục để quay lại mật khẩu cũ.
- **Maximum password age (1.1.2):** Buộc mật khẩu phải được thay đổi sau một khoảng thời gian (tối đa 365 ngày, không được đặt 0 – có nghĩa là không bao

giờ hết hạn). Giảm cửa sổ thời gian mà kẻ tấn công có thể sử dụng mật khẩu bị đánh cắp.

- **Minimum password age (1.1.3):** Yêu cầu người dùng phải giữ một mật khẩu trong ít nhất 1 ngày trước khi có thể thay đổi, làm cho chính sách *Enforce password history* trở nên hiệu quả.
- **Minimum password length (1.1.4) & Relax minimum password length limits (1.1.6):** Bắt buộc độ dài mật khẩu tối thiểu 14 ký tự (cho phép vượt quá giới hạn 14 ký tự cũ). Mật khẩu dài hơn sẽ khó bị tấn công brute-force hoặc dò từ điển hơn đáng kể.
- **Password must meet complexity requirements (1.1.5):** Yêu cầu mật khẩu bao gồm ít nhất 3 trong 4 loại ký tự: chữ hoa, chữ thường, chữ số, ký tự đặc biệt. Làm tăng không gian tìm kiếm cho các công cụ bẻ khóa.
- **Store passwords using reversible encryption (1.1.7):** Ở trạng thái **Disabled**, đảm bảo mật khẩu không được lưu trữ dưới dạng có thể giải mã ngược (tương đương bản rõ). Ngăn chặn việc khai thác các giao thức yêu cầu giải mã mật khẩu.

b) Phân tích rủi ro

- **Tái sử dụng mật khẩu:** Nếu không thiết lập lưu giữ lịch sử mật khẩu (1.1.1) hoặc đặt giá trị thấp, người dùng có thể luân chuyển giữa một vài mật khẩu quen thuộc. Khi một mật khẩu bị lộ, kẻ tấn công có thể tiếp tục sử dụng nó sau các lần thay đổi mật khẩu giả mạo.
- **Mật khẩu không bao giờ hết hạn (1.1.2 = 0):** Tạo cơ hội cho kẻ tấn công có thời gian không giới hạn để bẻ khóa mật khẩu đã thu thập được (ví dụ qua hash dump). Đặc biệt nguy hiểm với các tài khoản đặc quyền.
- **Độ dài mật khẩu ngắn (1.1.4 < 14):** Các cuộc tấn công brute-force hiện đại có thể thử hàng tỷ tổ hợp mỗi giây. Mật khẩu 7 ký tự chỉ gồm chữ thường có thể bị bẻ khóa trong vòng 133 phút (theo tài liệu CIS).

- **Không yêu cầu độ phức tạp (1.1.5 = Disabled):** Người dùng có xu hướng đặt mật khẩu đơn giản như “Password123”. Các từ điển mật khẩu thông dụng có thể dễ dàng dò tìm.
- **Lưu trữ mật khẩu dạng mã hóa ngược được (1.1.7 = Enabled):** Mật khẩu được lưu dưới dạng tương đương bản rõ, khiến cho bất kỳ ai truy cập được vào database SAM (bằng kỹ thuật offline) đều có thể đọc trực tiếp mật khẩu mà không cần bẻ khóa.

3.1.2. Chính sách khóa tài khoản (Account Lockout Policy)

CIS ID	Tên chính sách	Giá trị yêu cầu
1.2.1	Account lockout duration	15 or more minute(s)
1.2.2	Account lockout threshold	5 or fewer invalid logon attempt(s), but not 0
1.2.3	Allow Administrator account lockout (MS only)	Enabled
1.2.4	Reset account lockout counter after	15 or more minute(s)

Bảng 3. Danh sách các chính sách khóa tài khoản

a) Ý nghĩa bảo mật

- **Account lockout threshold (1.2.2):** Sau **5 lần** đăng nhập sai liên tiếp, tài khoản sẽ bị khóa. Giá trị 0 (không khóa) là không tuân thủ. Điều này làm chậm đáng kể các cuộc tấn công brute-force trực tuyến.
- **Account lockout duration (1.2.1):** Tài khoản bị khóa sẽ giữ nguyên trạng thái khóa trong ít nhất **15 phút** (hoặc lâu hơn). Tránh việc khóa vĩnh viễn gây từ chối dịch vụ (DoS) nhưng vẫn đủ dài để gây khó khăn cho kẻ tấn công.
- **Reset account lockout counter after (1.2.4):** Bộ đếm số lần sai được đặt lại về 0 sau 15 phút kể từ lần sai cuối cùng. Điều này tránh trường hợp người dùng hợp pháp vô tình nhập sai vài lần trong một khoảng thời gian dài bị khóa oan.
- **Allow Administrator account lockout (1.2.3):** Áp dụng chính sách khóa cho chính tài khoản Administrator mặc định. Trước đây tài khoản này được miễn khóa, rất dễ bị tấn công brute-force.

b) Phân tích rủi ro

- **Không có ngưỡng khóa (1.2.2 = 0):** Kẻ tấn công có thể thử mật khẩu không giới hạn lần mà không sợ bị khóa tài khoản. Điều này đặc biệt nguy hiểm với các tài khoản dịch vụ hoặc quản trị có mật khẩu yếu.
- **Thời gian khóa quá ngắn hoặc đặt lại bộ đếm quá nhanh:** Kẻ tấn công có thể lợi dụng để thực hiện tấn công từ chối dịch vụ (khóa hàng loạt tài khoản) nếu thời gian khóa quá lâu, hoặc ngược lại nếu thời gian khóa quá ngắn (dưới 15 phút) và bộ đếm đặt lại nhanh, kẻ tấn công có thể tiếp tục thử mật khẩu chỉ sau một khoảng nghỉ ngắn.
- **Không khóa tài khoản Administrator (1.2.3 = Disabled):** Tài khoản Administrator mặc định (thường không bị khóa) trở thành mục tiêu số một của các cuộc tấn công brute-force. Kẻ tấn công có thể thử hàng triệu mật khẩu mà không sợ bị khóa.

3.1.3. Gán quyền người dùng (User Rights Assignment)

CIS ID	Tên chính sách	Giá trị yêu cầu
2.2.1	Access Credential Manager as a trusted caller	No One
2.2.2	Access this computer from the network (DC only)	Administrators, Authenticated Users, ENTERPRISE DOMAIN CONTROLLERS
2.2.3	Access this computer from the network (MS only)	Administrators, Authenticated Users
2.2.4	Act as part of the operating system	No One
2.2.5	Add workstations to domain (DC only)	Administrators
2.2.6	Adjust memory quotas for a process	Administrators, LOCAL SERVICE, NETWORK SERVICE
2.2.7	Allow log on locally (DC only)	Administrators, ENTERPRISE DOMAIN CONTROLLERS
2.2.8	Allow log on locally (MS only)	Administrators

2.2.9	Allow log on through Remote Desktop Services (DC only)	Administrators
2.2.10	Allow log on through Remote Desktop Services (MS only)	Administrators, Remote Desktop Users
2.2.11	Back up files and directories	Administrators
2.2.12	Change the system time	Administrators, LOCAL SERVICE
2.2.13	Create a pagefile	Administrators
2.2.14	Create a token object	No One
2.2.15	Create global objects	Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE
2.2.16	Create permanent shared objects	No One
2.2.17	Create symbolic links (DC only)	Administrators
2.2.18	Create symbolic links (MS only)	Administrators, NT VIRTUAL MACHINE\Virtual Machines
2.2.19	Debug programs	Administrators
2.2.20	Deny access to this computer from the network (DC only)	Guests
2.2.21	Deny access to this computer from the network (MS only)	Guests, Local account and member of Administrators group
2.2.22	Deny log on as a batch job	Guests
2.2.23	Deny log on as a service	Guests
2.2.24	Deny log on locally	Guests
2.2.25	Deny log on through Remote Desktop Services (DC only)	Guests
2.2.26	Deny log on through Remote Desktop Services (MS only)	Guests, Local account
2.2.27	Enable computer and user accounts to be trusted for delegation (DC only)	Administrators
2.2.28	Enable computer and user accounts to be	No One

	trusted for delegation (MS only)	
2.2.29	Force shutdown from a remote system	Administrators
2.2.30	Generate security audits	LOCAL SERVICE, NETWORK SERVICE
2.2.31	Impersonate a client after authentication (DC only)	Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE
2.2.32	Impersonate a client after authentication (MS only)	Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE (và IIS_IUSRS nếu cần)
2.2.33	Increase scheduling priority	Administrators, Window Manager\Window Manager Group
2.2.34	Load and unload device drivers	Administrators
2.2.35	Lock pages in memory	No One
2.2.36	Log on as a batch job (DC Only)	Administrators
2.2.37	Manage auditing and security log (DC only)	Administrators
2.2.38	Manage auditing and security log (MS only)	Administrators
2.2.39	Modify an object label	No One
2.2.40	Modify firmware environment values	Administrators
2.2.41	Perform volume maintenance tasks	Administrators
2.2.42	Profile single process	Administrators
2.2.43	Profile system performance	Administrators, NT SERVICE\WdiServiceHost
2.2.44	Replace a process level token	LOCAL SERVICE, NETWORK SERVICE
2.2.45	Restore files and directories	Administrators
2.2.46	Shut down the system	Administrators
2.2.47	Synchronize directory service data (DC only)	No One
2.2.48	Take ownership of files or other objects	Administrators

Bảng 4. Danh sách các chính sách Gán quyền người dùng

a) Ý nghĩa bảo mật

- **Hạn chế tối đa các quyền nhạy cảm:** Các quyền như *Act as part of the operating system*, *Debug programs*, *Create a token object* chỉ được gán cho **No One**. Điều này ngăn chặn kẻ tấn công leo thang đặc quyền lên mức SYSTEM hoặc can thiệp sâu vào kernel.
- **Kiểm soát truy cập mạng và đăng nhập cục bộ:**
 - *Access this computer from the network* chỉ gán cho **Administrators**, **Authenticated Users** (và thêm **ENTERPRISE DOMAIN CONTROLLERS** trên DC). Loại bỏ nhóm Everyone, giảm nguy cơ truy cập trái phép.
 - *Allow log on locally* chỉ gán cho **Administrators** (trên DC thêm **ENTERPRISE DOMAIN CONTROLLERS**). Người dùng thông thường không thể đăng nhập trực tiếp vào máy chủ, giảm tấn công qua console.
- **Từ chối các quyền cho nhóm Guests:** Các chính sách *Deny ...* được cấu hình để từ chối Guests đăng nhập dưới mọi hình thức (qua mạng, batch job, service, local, RDP). Ngăn chặn tài khoản ẩn danh hoặc khách truy cập tài nguyên hệ thống.
- **Bảo vệ các tiến trình và dữ liệu nhạy cảm:**
 - *Back up files and directories*, *Restore files and directories* chỉ gán cho Administrators, tránh việc sao lưu/lấy cắp dữ liệu bởi người dùng không có thẩm quyền.
 - *Debug programs* chỉ dành cho Administrators, ngăn chặn việc gắn debugger vào các tiến trình hệ thống để trích xuất thông tin bộ nhớ (hash, mật khẩu).
- **Quản lý đặc quyền ủy quyền:** *Enable computer and user accounts to be trusted for delegation* chỉ gán cho Administrators trên DC, và **No One** trên Member Server. Hạn chế khả năng mạo danh người dùng khác trong mạng.

b) Phân tích rủi ro

- **Gán quyền quá rộng (ví dụ Everyone hoặc Users):** Nếu *Access this computer from the network* cho phép Everyone, bất kỳ người dùng ẩn danh nào cũng có thể kết nối đến máy chủ, liệt kê tài khoản, chia sẻ và có thể khai thác lỗ hổng dịch vụ mạng.
- **Cho phép gỡ lỗi (Debug programs) cho người dùng không phải quản trị:** Kẻ tấn công sau khi xâm nhập được một tài khoản thường có thể chạy debugger để đọc bộ nhớ tiến trình LSASS, từ đó trích xuất hash mật khẩu NTLM và thực hiện tấn công pass-the-hash.
- **Không từ chối Guests:** Nếu không cấu hình các *Deny* cho Guests, tài khoản Guest (mặc định bị vô hiệu hóa nhưng có thể bị kích hoạt bất hợp pháp) sẽ có thể đăng nhập qua mạng hoặc qua RDP, mở đường cho truy cập trái phép.
- **Gán quyền *Impersonate a client after authentication* cho quá nhiều đối tượng:** Nếu một dịch vụ độc hại có quyền này, nó có thể mạo danh bất kỳ người dùng nào kết nối đến nó, dẫn đến leo thang đặc quyền nghiêm trọng.
- **Quyền *Take ownership* bị lạm dụng:** Người dùng có quyền *Take ownership of files or other objects* có thể chiếm quyền sở hữu bất kỳ tệp tin hoặc đối tượng nào, bỏ qua mọi ACL, từ đó đọc dữ liệu bí mật hoặc sửa đổi cấu hình hệ thống.

3.1.4. Các tùy chọn bảo mật – Tài khoản (Security Options – Accounts)

CIS ID	Tên chính sách	Giá trị yêu cầu
2.3.1.1	Accounts: Guest account status (MS only)	Disabled
2.3.1.2	Accounts: Limit local account use of blank passwords to console logon only	Enabled
2.3.1.3	Accounts: Rename administrator account	(tên mới, không chứa từ “admin”/”administrator”)
2.3.1.4	Accounts: Rename guest account	(tên mới, không gợi ý là guest)

Bảng 5. Danh sách các chính sách Bảo mật – Tài khoản

a) Ý nghĩa bảo mật

- **Guest account status (2.3.1.1):** Vô hiệu hóa hoàn toàn tài khoản Guest, ngăn chặn bất kỳ truy cập ẩn danh hoặc không xác thực nào vào hệ thống qua tài khoản này.
- **Limit blank passwords (2.3.1.2):** Các tài khoản local có mật khẩu trống chỉ được phép đăng nhập từ bàn phím vật lý (console), không thể đăng nhập từ xa qua mạng. Giảm nguy cơ tài khoản yếu bị khai thác từ xa.
- **Rename administrator/guest account (2.3.1.3, 2.3.1.4):** Đổi tên tài khoản Administrator và Guest mặc định thành tên khó đoán. Làm phức tạp các cuộc tấn công brute-force vì kẻ tấn công không biết chính xác tên tài khoản đặc quyền.

b) Phân tích rủi ro

- **Tài khoản Guest được kích hoạt (2.3.1.1 = Enabled):** Bất kỳ người dùng mạng nào cũng có thể truy cập hệ thống với quyền Guest, thường có thể đọc các share công cộng hoặc thực hiện liệt kê thông tin. Nguy cơ rò rỉ dữ liệu và leo thang đặc quyền nếu Guest vô tình có quyền ghi trên một số tài nguyên.
- **Cho phép đăng nhập từ xa với mật khẩu trống (2.3.1.2 = Disabled):** Một máy chủ có tài khoản local với mật khẩu trống (ví dụ tài khoản dùng cho khôi phục khẩn cấp) có thể bị tấn công từ xa mà không cần mật khẩu, đặc biệt nguy hiểm nếu tài khoản đó nằm trong nhóm Administrators.
- **Giữ nguyên tên Administrator mặc định (2.3.1.3):** Tài khoản Administrator có SID nổi tiếng (S-1-5-21...-500) nhưng việc giữ tên gốc giúp kẻ tấn công dễ dàng xác định mục tiêu. Mặc dù có thể tấn công qua SID, việc đổi tên vẫn làm tăng độ khó cho các công cụ tấn công tự động dựa trên tên người dùng.
- **Giữ nguyên tên Guest:** Tương tự, tài khoản Guest dù bị vô hiệu hóa vẫn có thể bị kích hoạt trái phép bởi phần mềm độc hại. Đổi tên làm giảm khả năng khai thác sau này.

3.2. Network and Services Security

3.2.1. Network Security and Access

CIS ID	Tên chính sách	Giá trị yêu cầu
2.3.8.1	Microsoft network client: Digitally sign communications (always)	Enabled
2.3.8.2	Microsoft network client: Send unencrypted password to third-party SMB servers	Disabled
2.3.9.1	Microsoft network server: Amount of idle time required before suspending session	15 or fewer minute(s)
2.3.9.2	Microsoft network server: Digitally sign communications (always)	Enabled
2.3.9.3	Microsoft network server: Disconnect clients when logon hours expire	Enabled
2.3.9.4	Microsoft network server: Server SPN target name validation level	Accept if provided by client or higher
2.3.10.1	Network access: Allow anonymous SID/Name	Disabled

CIS ID	Tên chính sách	Giá trị yêu cầu
	translation	
2.3.10.2	Network access: Do not allow anonymous enumeration of SAM accounts (MS only)	Enabled
2.3.10.3	Network access: Do not allow anonymous enumeration of SAM accounts and shares (MS only)	Enabled
2.3.10.5	Network access: Let Everyone permissions apply to anonymous users	Disabled
2.3.10.6	Network access: Named Pipes that can be accessed anonymously (DC only)	Configured
2.3.10.7	Network access: Named Pipes that can be accessed anonymously (MS only)	Configured
2.3.10.8	Network access: Remotely accessible registry paths	Configured
2.3.10.9	Network access: Remotely accessible registry paths and sub-paths	Configured
2.3.10.10	Network access: Restrict anonymous access to Named Pipes and Shares	Enabled
2.3.10.11	Network access: Restrict clients allowed to make remote calls to SAM	Administrators: Remote Access: Allow

CIS ID	Tên chính sách	Giá trị yêu cầu
2.3.10.12	Network access: Shares that can be accessed anonymously	None
2.3.10.13	Network access: Sharing and security model for local accounts	Classic - local users authenticate as themselves
2.3.11.1	Network security: Allow Local System to use computer identity for NTLM	Enabled
2.3.11.2	Network security: Allow LocalSystem NULL session fallback	Disabled
2.3.11.3	Network Security: Allow PKU2U authentication requests to this computer to use online identities	Disabled
2.3.11.4	Network security: Configure encryption types allowed for Kerberos	AES128_HMAC_SHA1, AES256_HMAC_SHA1, Future encryption types
2.3.11.5	Network security: Do not store LAN Manager hash value on next password change	Enabled
2.3.11.6	Network security: Force logoff when logon hours expire	Enabled
2.3.11.7	Network security: LAN Manager authentication level	Send NTLMv2 response only. Refuse LM & NTLM

CIS ID	Tên chính sách	Giá trị yêu cầu
2.3.11.8	Network security: LDAP client signing requirements	Negotiate signing or higher
2.3.11.9	Network security: Minimum session security for NTLM SSP based clients	Require NTLMv2 session security, Require 128-bit encryption
2.3.11.10	Network security: Minimum session security for NTLM SSP based servers	Require NTLMv2 session security, Require 128-bit encryption
2.3.11.11	Network security: Restrict NTLM: Audit Incoming NTLM Traffic	Enable auditing for all accounts
2.3.11.12	Network security: Restrict NTLM: Audit NTLM authentication in this domain (DC only)	Enable all
2.3.11.13	Network security: Restrict NTLM: Outgoing NTLM traffic to remote servers	Audit all or higher
18.6.4.1	Configure multicast DNS (mDNS) protocol	Disabled
18.6.4.2	Configure NetBIOS settings	Enabled: Disable NetBIOS name resolution on public networks
18.6.4.4	Turn off multicast name resolution	Enabled

CIS ID	Tên chính sách	Giá trị yêu cầu
18.6.7.1	Mandate the minimum version of SMB	Enabled: 3.1.1
18.6.8.1	Enable insecure guest logons	Disabled
18.6.8.2	Require Encryption	Enabled
18.6.11.2	Prohibit installation and configuration of Network Bridge on your DNS domain network	Enabled
18.6.11.3	Prohibit use of Internet Connection Sharing on your DNS domain network	Enabled
18.6.11.4	Require domain users to elevate when setting a network's location	Enabled
18.6.14.1	Hardened UNC Paths	Enabled, with "Require Mutual Authentication"
18.6.21.1	Minimize the number of simultaneous connections to the Internet or a Windows Domain	Enabled: 3 = Prevent Wi-Fi when on Ethernet

Bảng 6. Danh sách các chính sách Network Security and Access

a) Ý nghĩa bảo mật

Phần này quy định các tiêu chuẩn mã hóa đường truyền, giao thức xác thực và quyền truy cập ẩn danh (Anonymous/Null session). Nó đảm bảo rằng mọi liên lạc giữa Windows Server với các máy khách hoặc các máy chủ khác đều được xác thực và bảo vệ tính toàn vẹn

b) Phân tích rủi ro

+ Xác thực yếu và thiếu mã hóa: Việc tiếp tục sử dụng các giao thức cũ như LM, NTLMv1 hoặc cho phép SMB truyền mật khẩu dạng bản rõ tạo điều kiện cho tin tặc thực hiện các cuộc tấn công nghe lén, tấn công xen giữa, và bẻ khóa mật khẩu.

+ Khai thác truy cập ẩn danh: Nếu hệ thống cho phép dịch ngược SID, liệt kê tài khoản SAM hoặc chia sẻ Named Pipes ẩn danh, kẻ tấn công có thể dễ dàng dò quét toàn bộ kiến trúc tài khoản của hệ thống mà không cần cung cấp bất kỳ thông tin đăng nhập nào.

3.2.2. Windows Firewall

CIS ID	Tên chính sách	Giá trị yêu cầu
9.1.1	Windows Firewall: Domain: Firewall state	On (recommended)
9.1.2	Windows Firewall: Domain: Inbound connections	Block (default)
9.1.3	Windows Firewall: Domain: Settings: Display a notification	No
9.1.4	Windows Firewall: Domain: Logging: Name	Configured
9.1.5	Windows Firewall: Domain: Logging: Size limit (KB)	16,384 KB or greater
9.1.6	Windows Firewall: Domain: Logging: Log dropped packets	Yes
9.1.7	Windows Firewall: Domain: Logging: Log successful connections	Yes

CIS ID	Tên chính sách	Giá trị yêu cầu
9.2.1 -> 9.2.7	Windows Firewall: Private Profile (Các quy tắc State, Inbound, Notify, Logging tương tự Domain)	On, Block, No, Configured, 16384, Yes, Yes
9.3.1 -> 9.3.3	Windows Firewall: Public Profile (State, Inbound, Notify)	On, Block, No
9.3.4	Windows Firewall: Public: Settings: Apply local firewall rules	No
9.3.5	Windows Firewall: Public: Settings: Apply local connection security rules	No
9.3.6 -> 9.3.9	Windows Firewall: Public Profile (Logging Name, Size, Dropped, Successful)	Configured, 16384, Yes, Yes

Bảng 7. Danh sách các chính sách Windows Firewall

a) Ý nghĩa bảo mật

Tường lửa Windows là chốt chặn đầu tiên kiểm soát toàn bộ lưu lượng mạng ra/vào máy chủ dựa trên 3 cấu hình độc lập: Domain, Private và Public Profile

b) Phân tích rủi ro

+ Thiếu kiểm soát Inbound: Nếu không thiết lập chính sách “Block default” cho các kết nối đến, các dịch vụ không cần thiết sẽ vô tình bị phơi bày ra môi trường mạng, tạo điều kiện cho mã độc lây lan ngang.

+ Che giấu dấu vết: Nếu không kích hoạt tính năng ghi nhật ký các gói tin bị từ chối với dung lượng lớn, đội ngũ quản trị sẽ mất hoàn toàn khả năng theo dõi khi hệ thống bị rà quét lỗ hổng. Ngoài ra việc cho phép ghi đè các “Local rules” trên Public Network có thể phá vỡ tính toàn vẹn của bảo mật tập trung (GPO).

3.2.3. Services, Printers and RDP

CIS ID	Tên chính sách (Policy Name)	Giá trị yêu cầu
5.1	Ensure 'Print Spooler (Spooler)' is set to 'Disabled' (DC only)	Disabled
18.7.1	Allow Print Spooler to accept client connections	Disabled
18.7.2	Configure Redirection Guard	Enabled: Redirection Guard Enabled
18.7.3	Configure RPC connection settings: Protocol to use for outgoing RPC connections	Enabled: RPC over TCP
18.7.4	Configure RPC connection settings: Use authentication for outgoing RPC connections	Enabled: Default
18.7.5	Configure RPC listener settings: Protocols to allow for incoming RPC connections	Enabled: RPC over TCP
18.7.6	Configure RPC listener settings: Authentication protocol to use for incoming RPC connections	Enabled: Negotiate or higher
18.7.7	Configure RPC over TCP port	Enabled: 0
18.7.8	Configure RPC packet level privacy setting for incoming connections	Enabled

CIS ID	Tên chính sách (Policy Name)	Giá trị yêu cầu
18.7.9	Limits print driver installation to Administrators	Enabled
18.7.10	Manage processing of Queue-specific files	Enabled: Limit Queue-specific files to Color profiles
18.7.11	Point and Print Restrictions: When installing drivers for a new connection	Enabled: Show warning and elevation prompt
18.7.12	Point and Print Restrictions: When updating drivers for an existing connection	Enabled: Show warning and elevation prompt
18.10.57.2.2	Do not allow passwords to be saved	Enabled
18.10.57.3.3.3	Do not allow drive redirection	Enabled
18.10.57.3.9.1	Always prompt for password upon connection	Enabled
18.10.57.3.9.2	Require secure RPC communication	Enabled
18.10.57.3.9.3	Require use of specific security layer for remote (RDP) connections	Enabled: SSL
18.10.57.3.9.4	Require user authentication for remote connections by using Network Level Authentication	Enabled
18.10.57.3.9.5	Set client connection encryption level	Enabled: High Level

CIS ID	Tên chính sách (Policy Name)	Giá trị yêu cầu
18.10.57.3.11.1	Do not delete temp folders upon exit	Disabled
18.10.57.3.11.2	Do not use temporary folders per session	Disabled

Bảng 8. Danh sách các chính sách Services, Printers and RDP

a) Ý nghĩa bảo mật

Hạng mục này tập trung thu hẹp bề mặt tấn công của Windows Server bằng cách vô hiệu hóa các dịch vụ nên không cần thiết như là in ấn và thắt chặt các tiêu chuẩn kết nối quản trị từ xa (remote desktop)

b) Phân tích rủi ro

+ Nguy cơ từ Print Spooler: Mặc định dịch vụ máy in luôn bật kể cả trên Domain Controller. Lỗ hổng nghiêm trọng PrintNightmare (CVE-2021-34527, CVE-2021-1678) cho phép kẻ tấn công chen mã độc vào bộ đệm in và chiếm quyền System cục bộ dễ dàng nếu dịch vụ này hoặc RPC qua Named Pipes không bị chặn.

+ Khai thác RDP: Phiên quản trị từ xa (RDP) nếu không yêu cầu Network Level Authentication hoặc mã hóa SSL mức cao, tin tặc có thể mở vô số kết nối rác gây cạn kiệt tài nguyên (DoS) hoặc bắt gói tin để trích xuất dữ liệu nhạy cảm.

3.3. Auditing and Monitoring

3.3.1. Audit

CIS ID	Tên chính sách	Giá trị yêu cầu
2.3.2.1	<i>Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings</i>	Enabled
2.3.2.2	<i>Audit: Shut down system immediately if unable to log security audits</i>	Disabled

17.1.1	<i>Audit: Credential Validation</i>	Success and Failure
17.1.2	<i>Audit: Kerberos Authentication Service</i>	Success and Failure
17.1.3	<i>Audit: Kerberos Service Ticket Operations</i>	Success and Failure
17.2.1	<i>Audit: Application Group Management</i>	Success and Failure
17.2.2	<i>Audit: Computer Account Management</i>	Success
17.2.3	<i>Audit: Distribution Group Management</i>	Success
17.2.4	<i>Audit: Other Account Management Events</i>	Success
17.2.5	<i>Audit: Security Group Management</i>	Success
17.2.6	<i>Audit: User Account Management</i>	Success and Failure
17.3.1	<i>Audit: PNP Activity</i>	Success
17.3.2	<i>Audit: Process Creation</i>	Success
17.4.1	<i>Audit: Directory Service Access</i>	Failure
17.4.2	<i>Audit: Directory Service Changes</i>	Success
17.5.1	<i>Audit: Account Logout</i>	Failure
17.5.2	<i>Audit: Group Membership</i>	Success
17.5.3	<i>Audit: Logoff</i>	Success
17.5.4	<i>Audit: Logon</i>	Success and Failure
17.5.5	<i>Audit: Other Logon/Logoff Events</i>	Success and Failure
17.5.6	<i>Audit: Special Logon</i>	Success
17.6.1	<i>Audit: Detailed File System</i>	Failure
17.6.2	<i>Audit: File Share</i>	Success and Failure
17.6.3	<i>Audit: Other Object Access Events</i>	Success and Failure
17.6.4	<i>Audit: Removable Storage</i>	Success and Failure
17.7.1	<i>Audit: Audit Policy Change</i>	Success
17.7.2	<i>Audit: Authentication Policy Change</i>	Success
17.7.3	<i>Audit: Other Policy Change Events</i>	Success
17.7.4	<i>Audit: MPSSVC Rule-Level Policy Change</i>	Success and Failure
17.7.5	<i>Audit: Filtering Platform Policy Change</i>	Failure
17.8.1	<i>Audit: Sensitive Privilege Use</i>	Success
17.9.1	<i>Audit: IPsec Driver</i>	Success and Failure

17.9.2	<i>Audit: Other System Events</i>	Success and Failure
17.9.3	<i>Audit: Security State Change</i>	Success
17.9.4	<i>Audit: Security System Extension</i>	Success
17.9.5	<i>Audit: System Integrity</i>	Success and Failure

Bảng 9. Danh sách các chính sách Audit

a) Ý nghĩa bảo mật

- “Audit: Force audit policy subcategory settings (*Windows Vista or later*) to override audit policy category settings” ưu tiên các thiết lập audit chi tiết theo từng subcategory thay vì chỉ sử dụng cấu hình tổng quát theo category. Điều này cho phép quản trị viên kiểm soát và ghi nhận chính xác các sự kiện quan trọng như đăng nhập, thay đổi quyền, truy cập tài nguyên hay thực thi tiến trình, từ đó nâng cao khả năng giám sát và hỗ trợ điều tra sự cố bảo mật.

- “Audit: Shut down system immediately if unable to log security audits” đảm bảo hệ thống vẫn tiếp tục hoạt động ngay cả khi xảy ra lỗi ghi Security Log. Thiết lập này giúp duy trì tính sẵn sàng của dịch vụ và tránh nguy cơ hệ thống tự động shutdown gây gián đoạn hoạt động.

b) Phân tích rủi ro

Về nền tảng, nếu chính sách Force audit policy subcategory settings không được bật, các thiết lập audit chi tiết có thể bị ghi đè bởi cấu hình audit tổng quát, dẫn đến việc thiếu hoặc mất các log bảo mật quan trọng. Điều này làm giảm khả năng phát hiện truy cập trái phép, khó khăn trong việc điều tra forensic và tạo điều kiện cho kẻ tấn công che giấu hành vi.

- Tấn công từ chối dịch vụ (Deny of Service - DoS) bằng cách làm đầy bộ nhớ security log. Đối với chính sách “*Shut down system immediately if unable to log security audits*”, nếu được bật thì hệ thống sẽ tự động tắt khi không thể ghi log bảo mật. Tạo cơ hội cho kẻ tấn công tác động đến hoạt động của hệ thống. Khi cấu hình Disabled, hệ thống vẫn duy trì hoạt động nhưng có nguy cơ mất một phần dữ liệu log trong thời gian xảy ra lỗi ghi log.

- Rủi ro xác thực và đăng nhập (17.1.1, 17.1.2, 17.1.3, 17.5.4, 17.5.5, 17.5.6): Nếu không ghi nhận đầy đủ log xác thực và đăng nhập, hệ thống khó phát hiện brute-force, credential theft, Pass-the-Ticket hoặc truy cập trái phép.
- Rủi ro quản lý tài khoản và phân quyền (17.2.1 → 17.2.6): Việc thiếu audit thay đổi tài khoản hoặc nhóm quyền có thể khiến kẻ tấn công leo thang đặc quyền mà không bị phát hiện.
- Rủi ro thực thi mã độc và thiết bị ngoại vi (17.3.1, 17.3.2, 17.6.4): Không giám sát tiến trình hoặc thiết bị USB có thể dẫn đến malware execution và rò rỉ dữ liệu.
- Rủi ro Active Directory (17.4.1, 17.4.2): Thiếu log truy cập hoặc thay đổi AD sẽ làm giảm khả năng phát hiện tấn công vào Domain Controller.
- Rủi ro truy cập tài nguyên (17.6.1, 17.6.2, 17.6.3): Không audit truy cập file share và object access có thể gây thất thoát dữ liệu hoặc truy cập trái phép.
- Rủi ro thay đổi chính sách bảo mật (17.7.1 → 17.7.5): Nếu thay đổi audit policy hoặc firewall rule không được ghi nhận, kẻ tấn công có thể vô hiệu hóa cơ chế bảo vệ hệ thống.
- Rủi ro lạm dụng đặc quyền (17.8.1): Thiếu giám sát quyền nhạy cảm có thể dẫn đến privilege escalation và kiểm soát hệ thống trái phép.
- Rủi ro toàn vẹn và hệ thống (17.9.1 → 17.9.5): Không theo dõi trạng thái bảo mật và integrity system có thể khiến hành vi can thiệp kernel, driver hoặc thay đổi hệ thống không bị phát hiện.

3.3.2. Event Log Service

CIS ID	Tên chính sách	Giá trị yêu cầu
18.10.26.1.1	Application: Control Event Log behavior when the log file reaches its maximum size	Overwrite events as needed (0)
18.10.26.1.2	Application: Specify the maximum log file size (KB)	32768 KB
18.10.26.2.1	Security: Control Event Log behavior when the log file reaches its	Overwrite events as needed (0)

	maximum size	
18.10.26.2.2	Security: Specify the maximum log file size (KB)	196608 KB
18.10.26.3.1	Setup: Control Event Log behavior when the log file reaches its maximum size	Overwrite events as needed (0)
18.10.26.3.2	Setup: Specify the maximum log file size (KB)	≥ 32768 KB
18.10.26.4.1	System: Control Event Log behavior when the log file reaches its maximum size	Overwrite events as needed (0)
18.10.26.4.2	System: Specify the maximum log file size (KB)	≥ 32768 KB

Bảng 10. Danh sách các chính sách Event Log Service

a) Ý nghĩa bảo mật

- Application: Control Event Log behavior when the log file reaches its maximum size: Cho phép hệ thống tự động ghi đè log cũ khi đầy nhằm duy trì hoạt động ghi log liên tục cho ứng dụng.
- Application: Specify the maximum log file size: Thiết lập dung lượng phù hợp cho Application Log nhằm đảm bảo lưu trữ đủ sự kiện ứng dụng phục vụ giám sát và điều tra.
- Security: Control Event Log behavior when the log file reaches its maximum size: Đảm bảo Security Log luôn tiếp tục ghi nhận sự kiện bảo mật bằng cách tự động ghi đè log cũ khi đầy.
- Security: Specify the maximum log file size: Tăng dung lượng Security Log để lưu giữ nhiều sự kiện bảo mật hơn, hỗ trợ forensic và phát hiện tấn công.
- Setup: Control Event Log behavior when the log file reaches its maximum size: Duy trì khả năng ghi log trong quá trình cài đặt hoặc cập nhật hệ thống.

- Setup: Specify the maximum log file size: Đảm bảo đủ không gian lưu trữ các sự kiện cài đặt và cập nhật hệ thống.
- System: Control Event Log behavior when the log file reaches its maximum size: Cho phép System Log tiếp tục hoạt động ổn định mà không bị gián đoạn do đầy log.
- System: Specify the maximum log file size: Thiết lập dung lượng phù hợp cho System Log nhằm lưu giữ đầy đủ sự kiện hệ thống quan trọng.

b) Phân tích rủi ro

- Rủi ro mất log bảo mật (18.10.26.2.1, 18.10.26.2.2): Nếu Security Log quá nhỏ hoặc không được cấu hình ghi đè hợp lý, hệ thống có thể mất các sự kiện bảo mật quan trọng, gây khó khăn cho việc điều tra sự cố và phát hiện tấn công.
- Rủi ro gián đoạn ghi log (18.10.26.1.1, 18.10.26.3.1, 18.10.26.4.1): Nếu log đầy nhưng không cho phép overwrite, hệ thống có thể ngừng ghi log, làm mất khả năng giám sát hoạt động.
- Rủi ro thiếu dữ liệu forensic (18.10.26.1.2, 18.10.26.2.2, 18.10.26.3.2, 18.10.26.4.2): Dung lượng log quá nhỏ sẽ khiến log cũ bị ghi đè nhanh chóng, làm giảm thời gian lưu trữ và ảnh hưởng đến quá trình điều tra forensic.
- Rủi ro ảnh hưởng hiệu năng lưu trữ (toàn bộ chính sách Event Log): Nếu cấu hình dung lượng log quá lớn mà không có cơ chế quản lý phù hợp, hệ thống có thể tiêu tốn nhiều dung lượng đĩa và ảnh hưởng hiệu năng máy chủ.

3.4. System Hardening and Antimalware

Phần này tập trung vào việc tăng cường khả năng tự phòng vệ của hệ điều hành Windows Server 2022 trước các nguy cơ như mã độc thực thi trái phép, fileless malware, lây nhiễm qua USB, khai thác bộ nhớ, đánh cắp thông tin xác thực cục bộ và leo thang đặc quyền. Nếu các nhóm chính sách về tài khoản và mạng giúp giảm nguy cơ xâm nhập ban đầu, thì nhóm System Hardening and Antimalware giúp giảm khả năng mã độc tồn tại, thực thi và mở rộng quyền kiểm soát sau khi đã có chỗ đứng trên hệ thống.

Trong phạm vi đồ án, nhóm chính sách này bao gồm các cấu hình quan trọng của Microsoft Defender Antivirus, MS Security Guide, MSS (Legacy), User Account

Control (UAC), Device Guard, Local Security Authority (LSA), AutoPlay Policies, Early Launch Antimalware (ELAM) và Windows Defender SmartScreen.

3.4.1. Microsoft Defender Antivirus

CIS ID	Tên chính sách	Giá trị yêu cầu
18.10.42.4.1	Enable EDR in block mode	Enabled
18.10.42.5.1	Configure local setting override for reporting to Microsoft MAPS	Disabled
18.10.42.5.2	Join Microsoft MAPS	Enabled: Advanced
18.10.42.6.1.1	Configure Attack Surface Reduction rules	Enabled
18.10.42.6.1.2	Configure Attack Surface Reduction rules: Set the state for each ASR rule	Configured
18.10.42.6.3.1	Prevent users and apps from accessing dangerous websites	Enabled: Block
18.10.42.10.2	Scan all downloaded files and attachments	Enabled
18.10.42.10.3	Turn off real-time protection	Disabled
18.10.42.10.4	Turn on behavior monitoring	Enabled
18.10.42.10.5	Turn on script scanning	Enabled
18.10.42.11.1.1.1	Configure Brute-Force Protection aggressiveness	Enabled: Medium or higher
18.10.42.13.3	Scan removable drives	Enabled
18.10.42.16	Configure detection for potentially unwanted applications	Enabled: Block

a) Ý nghĩa bảo mật

Tăng khả năng phát hiện và ngăn chặn mã độc ngay khi tệp được tải xuống, mở hoặc thực thi.

Giảm bề mặt tấn công nhờ Attack Surface Reduction, giám sát hành vi và quét script.

Hạn chế lây nhiễm qua e-mail, USB, website độc hại và phần mềm không mong muốn (PUA).

b) Phân tích rủi ro

Nếu tắt bảo vệ thời gian thực, mã độc có thể chạy mà không bị chặn kịp thời.

Nếu không cấu hình ASR, các công cụ hợp pháp như Office, PowerShell hoặc WMI có thể bị lợi dụng để thực thi mã độc.

Nếu không quét tệp tải về hoặc thiết bị rời, hệ thống dễ bị lây nhiễm từ nguồn bên ngoài.

3.4.2. MS Security Guide, MSS (Legacy) và UAC

CIS ID	Tên chính sách	Giá trị yêu cầu
18.4.1	Apply UAC restrictions to local accounts on network logons	Enabled
18.4.2	Configure SMB v1 client driver	Enabled: Disable driver
18.4.3	Configure SMB v1 server	Disabled
18.4.4	Enable Certificate Padding	Enabled
18.4.5	Enable Structured Exception Handling Overwrite Protection (SEHOP)	Enabled
18.4.6	NetBT NodeType configuration	Enabled: P-node
18.5.1	MSS: (AutoAdminLogon) Enable Automatic Logon	Disabled
18.5.2	MSS: (DisableIPSourceRouting IPv6) IP source routing protection level	Enabled: Highest protection
18.5.3	MSS: (DisableIPSourceRouting) IP source	Enabled: Highest

	routing protection level	protection
18.5.4	MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes	Disabled
18.5.8	MSS: (SafeDllSearchMode) Enable Safe DLL search mode	Enabled
2.3.17.1	UAC: Admin Approval Mode for the Built-in Administrator account	Enabled
2.3.17.2	UAC: Behavior of the elevation prompt for administrators in Admin Approval Mode	Prompt for consent on the secure desktop
2.3.17.3	UAC: Behavior of the elevation prompt for standard users	Automatically deny elevation requests
2.3.17.6	UAC: Run all administrators in Admin Approval Mode	Enabled
2.3.17.7	UAC: Switch to the secure desktop when prompting for elevation	Enabled

a) Ý nghĩa bảo mật

Loại bỏ các giao thức và cơ chế cũ, yếu như SMBv1 và AutoAdminLogon.

Tăng khả năng chống khai thác nội bộ thông qua SEHOP, SafeDllSearchMode và các ràng buộc UAC. Hạn chế việc tiến trình trái phép tự động nâng quyền quản trị.

b) Phân tích rủi ro

Nếu SMBv1 còn hoạt động, hệ thống có thể bị khai thác qua các lỗ hổng đã biết hoặc bị lạm dụng cho di chuyển ngang. Nếu UAC bị nói lỏng, mã độc có thể âm thầm chạy với quyền quản trị. Nếu tự động đăng nhập được bật, thông tin xác thực có thể bị lưu lại và bị đánh cắp.

Chương IV. PHƯƠNG PHÁP TRIỂN KHAI

4.1. Manual configuration

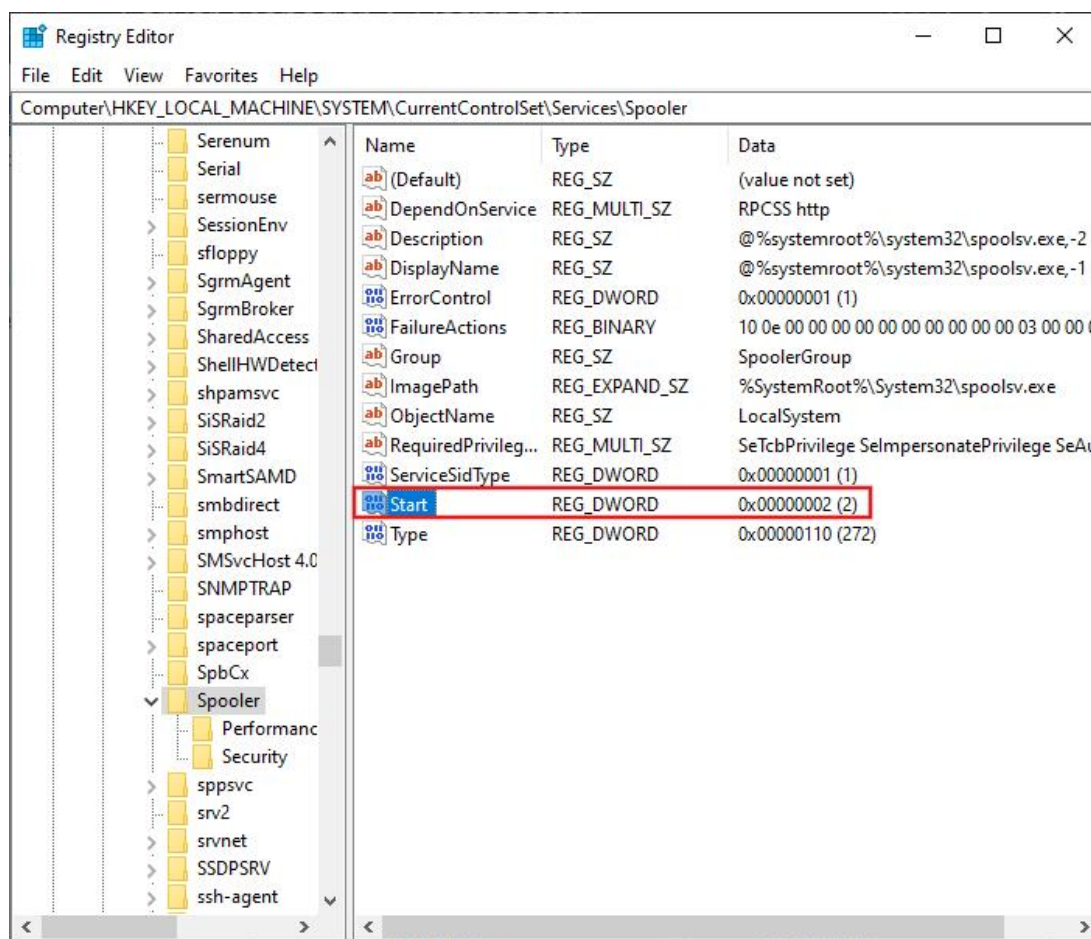
Cấu hình thủ công là phương pháp triển khai truyền thống được quản trị viên thực hiện qua giao diện đồ họa (GUI) hoặc giao diện dòng lệnh (CLI)

Giao diện đồ họa (GUI): Sử dụng regedit.exe để điều hướng đến các đường dẫn Registry và tinh chỉnh các khóa (Keys/Values). Sử dụng Local Group Policy Editor (gpedit.msc) và Local Security Policy (secpol.msc) để thiết lập các chính sách về mạng, kiểm toán và phân quyền người dùng.

Ví dụ: “Ensure 'Print Spooler (Spooler)' is set to 'Disabled' (DC only)”

+ Đánh giá hiện trạng: Trên máy DC-01, trong Registry, ta tìm Service Spooler theo đường

“HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Spooler”

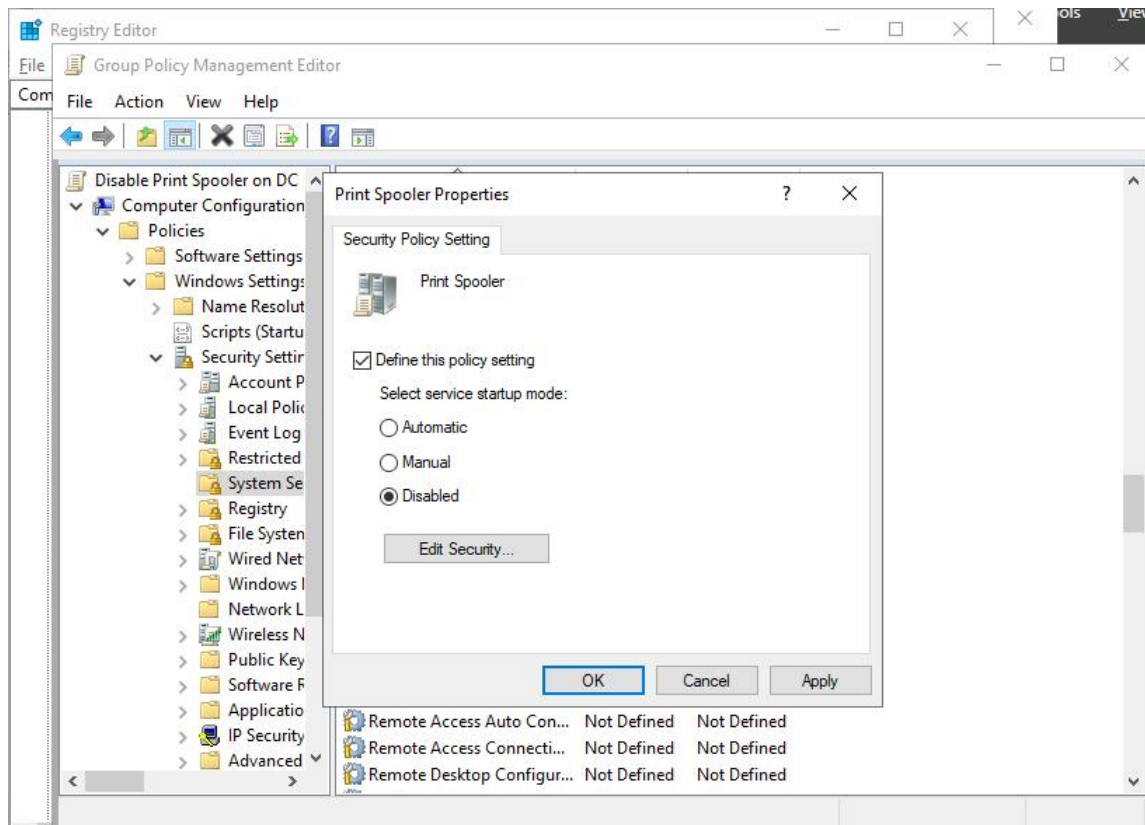


Hình 6. Giao diện Registry Editor hiển thị cấu hình dịch vụ Print Spooler

Như trên hình, giá trị của Start là 2-automatic, tức là nó sẽ được tự động khởi động cùng với hệ thống. Vì vậy hệ thống đang tồn tại rủi ro -> Không đạt chuẩn Level 1

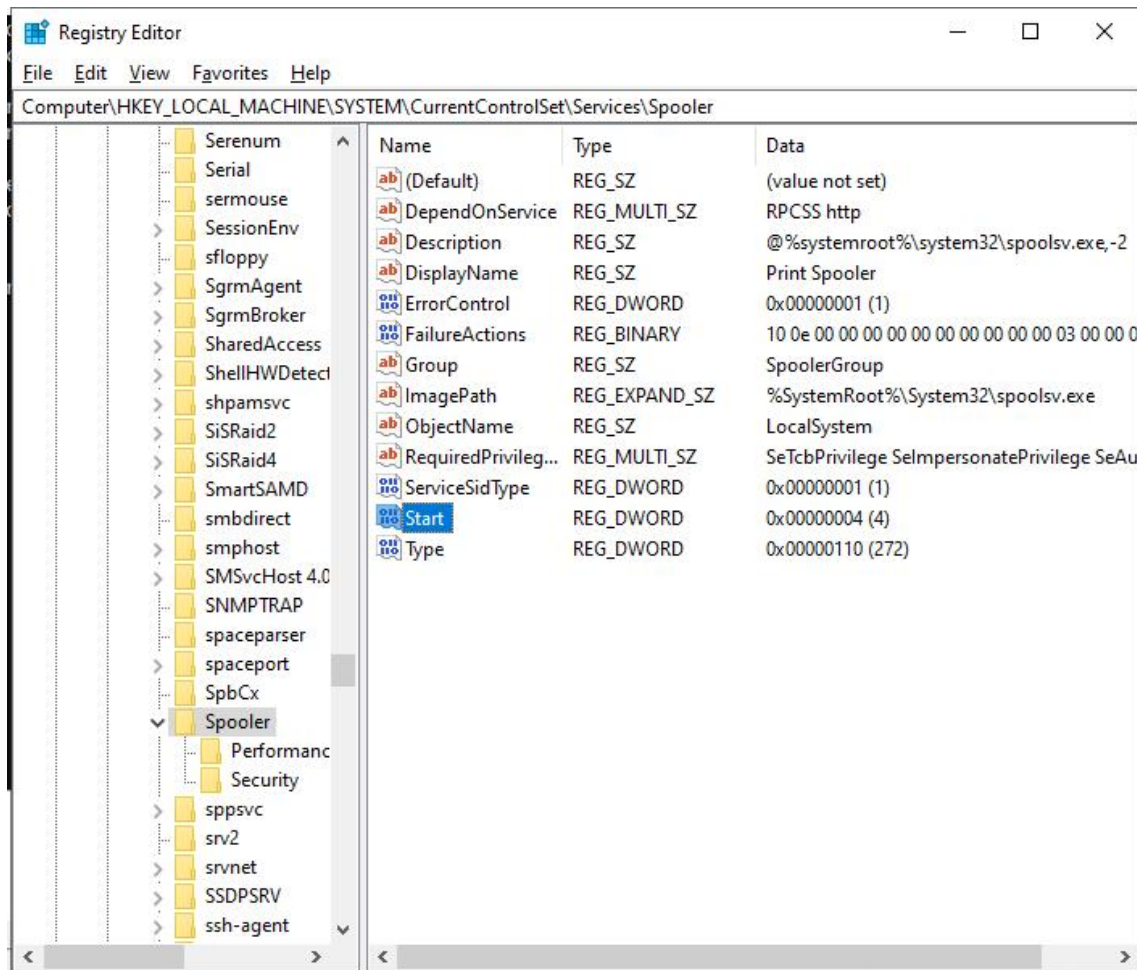
+ Khắc phục:

Trong Group Policy Management, ta tạo GPO và set giá trị của đường dẫn sau “Computer Configuration\Policies\Windows Settings\Security Settings\System Services\Print Spooler” thành Disabled



Hình 7. Cấu hình dịch vụ Print Spooler trong Registry Editor

Ta chạy lệnh “gpupdate /force” để áp dụng policy ngay. Sau đó kiểm tra lại services, ta thấy giá trị của Start đã chuyển sang 4-Disabled.



Hình 8. Giao diện Registry Editor hiển thị cấu hình dịch vụ Print Spooler sau điều chỉnh

Giao diện dòng lệnh (CLI): Sử dụng lệnh Powershell đơn lẻ để thực thi

Ví dụ: “Ensure 'Print Spooler (Spooler)' is set to 'Disabled' (DC only)”

+ Đánh giá hiện trạng: Trên DC01, ta kiểm tra bằng Powershell

```
PS C:\Users\Administrator> Get-ItemPropertyValue -Path "HKLM:\SYSTEM\CurrentControlSet\Services\Spooler" -Name "Start"
1
```

Qua ảnh trên, giá trị trả về khác 4, tức là hệ thống không đạt chuẩn Level 1

+ Khắc phục:

```
PS C:\Users\Administrator> Set-ItemProperty -Path "HKLM:\SYSTEM\CurrentControlSet\Services\Spooler" -Name "Start" -Value 4 -Type DWord
PS C:\Users\Administrator> Get-ItemPropertyValue -Path "HKLM:\SYSTEM\CurrentControlSet\Services\Spooler" -Name "Start"
4
PS C:\Users\Administrator>
```

-> **Đánh giá:** Phương pháp cấu hình thủ công có ưu điểm là dễ thực hiện, mang lại sự linh hoạt cao, giúp quản trị viên nắm bắt, kiểm soát chi tiết bản chất của từng chính sách bảo mật. Tuy nhiên, nhược điểm là vô cùng tốn thời gian, dễ xảy ra sai sót.

4.2. Tự động hóa cấu hình

Nhằm đảm bảo quá trình hardening Windows Server 2022 theo CIS được thực thi nhất quán, có thể lặp lại và dễ mở rộng, nhóm triển khai tự động hóa theo hai lớp: (1) chuẩn hóa kỹ thuật cấu hình bằng PowerShell script trên từng máy và (2) điều phối tập trung bằng Ansible trên toàn bộ hệ thống.

4.2.1 Tự động hóa sử dụng PowerShell Scripting

Nhận thấy việc chạy thủ công từng dòng lệnh hay cấu hình trên giao diện gây ra nhiều nhược điểm, nhóm gom các lệnh đó vào 1 script và chạy trên Windows PowerShell ISE của các máy Windows Server. Nhóm chạy các scripts là audit.ps1, remediation.ps1 và post-audit.ps1 tương ứng với kiểm tra và khắc phục. Phương pháp này đảm bảo chính xác cao và có khả năng tái sử dụng trên nhiều máy Windows Server riêng lẻ

4.2.2 Tự động hóa tập trung với Ansible

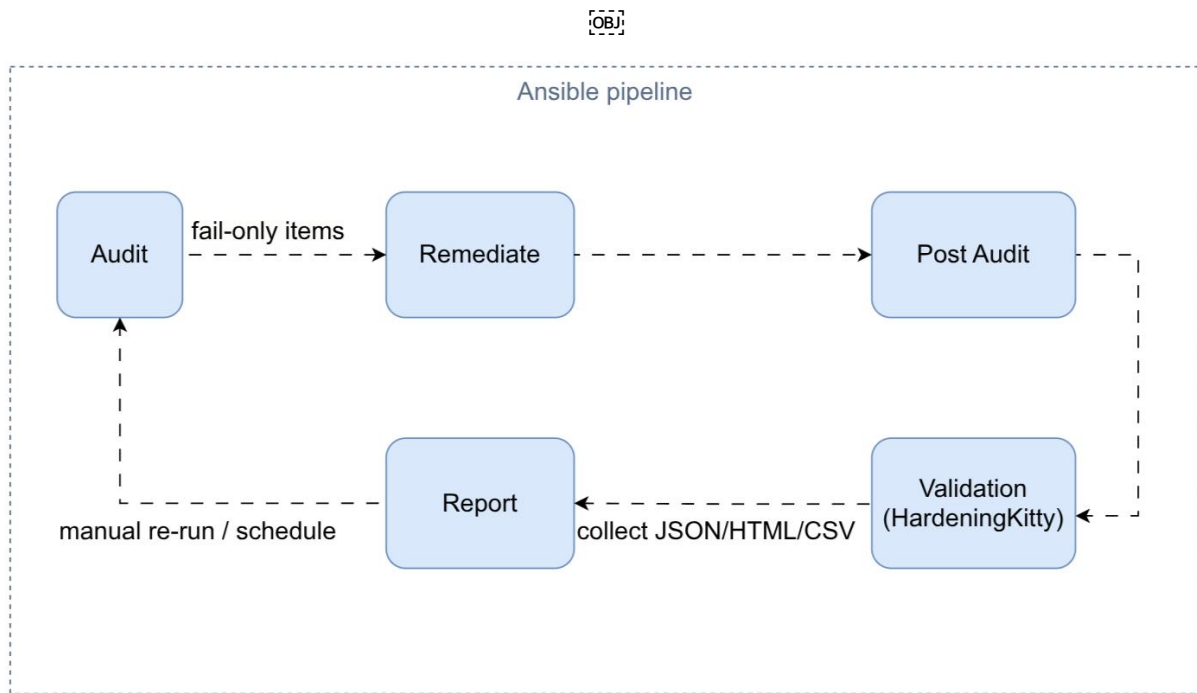
Sau khi chuẩn hóa lớp script, nhóm sử dụng Ansible để điều phối tập trung thay vì đăng nhập từng máy Windows để chạy thủ công. Ansible đảm nhiệm quản lý inventory, truyền script, kích hoạt thực thi theo pha và thu thập báo cáo về control node.

Pipeline triển khai được tổ chức tuần tự như sau:

- Audit: chạy kiểm tra baseline CIS trên các máy đích.
- Remediation: thực hiện cấu hình khắc phục theo các script đã chuẩn hóa.
- Post-Audit: đánh giá lại mức tuân thủ sau khi áp dụng cấu hình.
- Validation: kiểm chứng bổ sung bằng HardeningKitty.
- Report: thu thập và lưu báo cáo tập trung theo từng host/từng hạng mục.

Với kiến trúc này, quá trình hardening đạt các mục tiêu chính: giảm thao tác thủ công, tăng tính lặp lại, dễ mở rộng số lượng máy, và thuận tiện theo dõi tiến độ triển khai qua hệ thống báo cáo tập trung.

Bên cạnh đó, nhánh Wazuh được tích hợp song song để phục vụ giám sát sau triển khai, giúp duy trì góc nhìn vận hành và an ninh liên tục thay vì chỉ cấu hình một lần.



Hình 9. Pipeline tự động hóa

File `ansible/inventories/vm/group_vars/all.yml` là file cấu hình trung tâm của pipeline Ansible.

Nội dung chính gồm 2 phần:

- Global pipeline paths: chuẩn hóa toàn bộ đường dẫn local/remote (`pipeline_local_root`, `pipeline_remote_root`, `pipeline_remote_script_root`, `pipeline_remote_reports_*`) để Ansible biết nơi lấy script và nơi lưu báo cáo trên từng Windows node.
- `pipeline_role_matrix`: ánh xạ từng miền hardening (Identity Access Control, Network Services Security, Auditing Monitoring, System Hardening Antimalware) với bộ script tương ứng cho 3 pha audit, remediation, post_audit.

Cách tổ chức này giúp pipeline chạy nhất quán giữa các máy, dễ bảo trì khi đổi tên script/đường dẫn, và dễ mở rộng thêm module mà không cần sửa nhiều playbook.

```

NT542.Q22-Project > ansible > inventories > vm > group_vars > all.yml > ...
Ansible Vars File - Ansible variables File (vars.json)
1  # Global pipeline paths
2  pipeline_local_root: "{{ inventory_dir }}/../../pipeline"
3  pipeline_local_reports_root: "{{ pipeline_local_root }}/reports"
4
5  pipeline_remote_root: 'C:\\CIS-Automation'
6  pipeline_remote_script_root: '{{ pipeline_remote_root }}\\Scripts'
7  pipeline_remote_common_root: '{{ pipeline_remote_root }}\\common'
8  pipeline_remote_reports_json: '{{ pipeline_remote_root }}\\Reports\\JSON'
9  pipeline_remote_reports_html: '{{ pipeline_remote_root }}\\Reports\\HTML'
10
11 # Central role/script mapping
12 pipeline_role_matrix:
13     identity_access_control:
14         slug: identity-access-control
15         phase_script_dir: Identity-Access-Control
16         audit_script_name: Identity-Access-Control-Audit.ps1
17         remediation_script_name: Identity-Access-Control-Remediation.ps1
18         post_audit_script_name: Identity-Access-Control-Post-Audit.ps1
19
20     network_services_security:
21         slug: network-services-security
22         phase_script_dir: Network-Services-Security
23         audit_script_name: CIS-WinServer2022-Audit.ps1
24         remediation_script_name: CIS-WinServer2022-Remediation.ps1
25         post_audit_script_name: Network-Services-Security-Post-Audit.ps1
26
27     auditing_monitoring:
28         slug: auditing-monitoring
29         phase_script_dir: Auditing-Monitoring
30         audit_script_name: Auditing-Monitoring-Audit.ps1
31         remediation_script_name: Auditing-Monitoring-Remediation.ps1
32         post_audit_script_name: Auditing-Monitoring-Post-Audit.ps1
33
34     system_hardening_antimalware:
35         slug: system-hardening-antimalware
36         phase_script_dir: System-Hardening-Antimalware
37         audit_script_name: System-Hardening-Antimalware-Audit.ps1
38         remediation_script_name: System-Hardening-Antimalware-Remediation.ps1
39         post_audit_script_name: System-Hardening-Antimalware-Post-Audit.ps1

```

Hình 10. Cấu hình các biến môi trường sử dụng Ansible

Chương V. TOOL KIỂM ĐỊNH VÀ GIÁM SÁT TẬP TRUNG

5.1. HardeningKitty

5.1.1. Tích hợp vào hệ thống

Trong bối cảnh đồ án này, nhóm triển khai Hardening Kitty như một bước validation độc lập trong pipeline Ansible, thực hiện sau các pha Audit, Remediation và Post Audit. Cách tích hợp này giúp quy trình kiểm định cấu hình được tự động hóa hoàn toàn, không cần đăng nhập thủ công từ phía người quản trị vào từng máy chủ Windows Server.

Trong quá trình chạy, hệ thống chọn baseline kiểm định theo vai trò máy chủ: Domain Controller sử dụng finding list dành cho DC, còn Member Server sử dụng finding list dành cho member. HardeningKitty được đẩy lên host, thực thi ở chế độ audit, sau đó trả về các tệp kết quả gồm báo cáo chi tiết và phần tóm tắt chỉ số.

Phiên bản HardeningKitty được sử dụng là Microsoft Security Baseline Windows Server 2022 (21H2) cho DC/Member, kết quả được dùng để đối chiếu bổ sung, không thay thế hoàn toàn đánh giá CIS v5.0.0 của pipeline chính.

5.2. Wazuh

5.2.1. Tích hợp vào hệ thống

Trong đề tài, Wazuh được triển khai như nền tảng giám sát bảo mật tập trung cho môi trường Windows Server 2022. Hệ thống gồm một máy chủ Wazuh (manager/indexer/dashboard) và các Wazuh agent cài trên các máy đích như dc01, member01, fs01 để thu thập dữ liệu và gửi về đầu môi quản trị.

Trong phạm vi đồ án, Wazuh tập trung vào hai mục tiêu chính:

- Đánh giá tuân thủ cấu hình qua Security Configuration Assessment (SCA), sử dụng baseline tùy chỉnh bám theo 4 nhóm hardening của pipeline.
- Giám sát rủi ro sau hardening thông qua khả năng phát hiện lỗ hổng (Vulnerability Detection).

Cách tiếp cận này giúp bổ sung lớp giám sát vận hành liên tục sau triển khai, không chỉ dừng ở kiểm tra cấu hình một lần.

5.2.2. Kết quả triển khai Wazuh bằng Ansible

Nhóm đã thực thi playbook wazuh.yml để triển khai Wazuh manager trên log01 và cấu hình agent trên ba máy Windows: dc01, member01, fs01. Kết quả PLAY RECAP cho thấy toàn bộ host chạy thành công, không phát sinh lỗi (failed=0) và không có host mất kết nối (unreachable=0):

- dc01: ok=19, changed=8, failed=0
- member01: ok=19, changed=8, failed=0
- fs01: ok=19, changed=8, failed=0
- log01: ok=17, changed=5, failed=0

Task Wait until manager registers the agent đều trả về ok cho cả ba máy đích, cho thấy manager đã phản hồi đăng ký agent thành công trong phiên chạy này. Đồng thời, task Show Wazuh agent enrollment hint xác nhận:

- Manager target: 192.168.250.40 (đúng với máy manager hiện tại)
- Re-enrollment required: False trên cả 3 máy
- Chu kỳ quét SCA: 2m (mỗi hai phút)

Giá trị Manager already knows agent: False trong phần hint phản ánh trạng thái kiểm tra ban đầu trước khi hoàn tất toàn bộ quy trình cài đặt/cấu hình; tuy nhiên việc task chờ đăng ký trả về ok là chỉ dấu cho thấy agent đã được manager nhận diện sau khi playbook chạy xong. Sau bước này, nhóm xác nhận thêm trên Wazuh Dashboard để kiểm tra trạng thái online và kết quả SCA của từng agent.

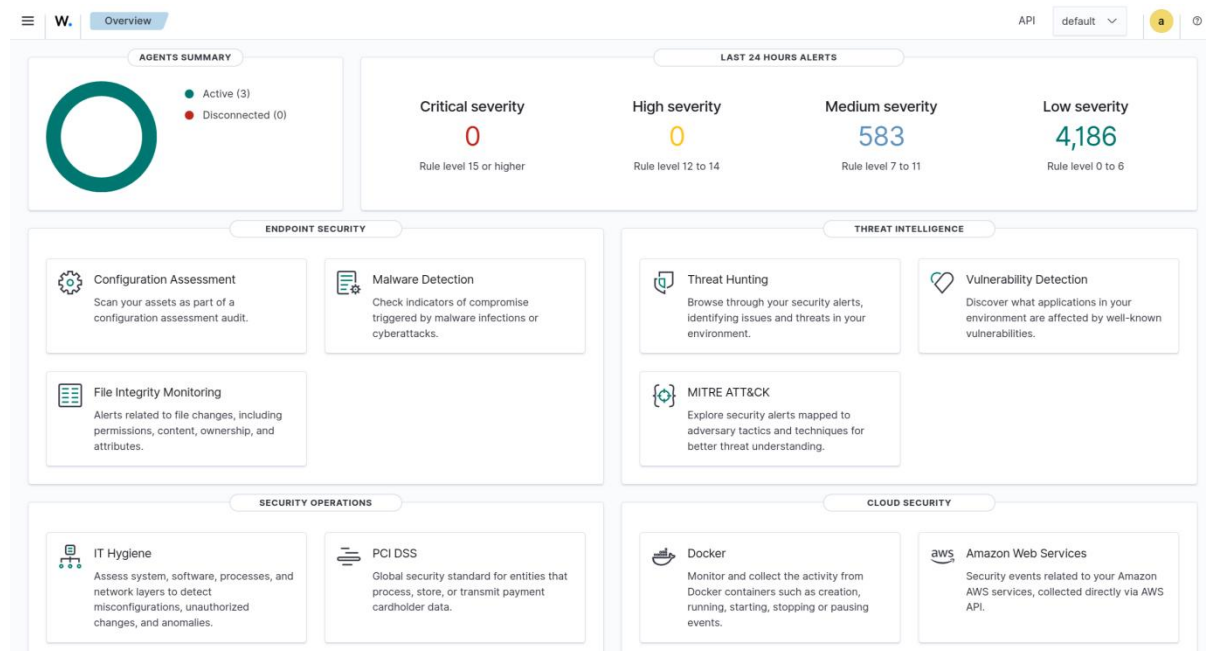
```

PROBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS ANSIBLE CODE REFERENCE LOG
TASK [wazuh_agent : Show Wazuh agent enrollment hint] *****
ok: [dc01] =>
  msg:
  - Wazuh agent installed on dc01.
  - 'Manager target: 192.168.250.40'
  - 'Manager already knows agent: False'
  - 'Re-enrollment required: False'
  - 'Custom SCA policy: C:\Program Files (x86)\ossec-agent\etc\shared\sca\cis_win2022_v5_custom_nt542.yml'
  - 'SCA scan interval: 2m'
  - Verify SCA results in Wazuh dashboard after next scan cycle.
ok: [member01] =>
  msg:
  - Wazuh agent installed on member01.
  - 'Manager target: 192.168.250.40'
  - 'Manager already knows agent: False'
  - 'Re-enrollment required: False'
  - 'Custom SCA policy: C:\Program Files (x86)\ossec-agent\etc\shared\sca\cis_win2022_v5_custom_nt542.yml'
  - 'SCA scan interval: 2m'
  - Verify SCA results in Wazuh dashboard after next scan cycle.
ok: [fs01] =>
  msg:
  - Wazuh agent installed on fs01.
  - 'Manager target: 192.168.250.40'
  - 'Manager already knows agent: False'
  - 'Re-enrollment required: False'
  - 'Custom SCA policy: C:\Program Files (x86)\ossec-agent\etc\shared\sca\cis_win2022_v5_custom_nt542.yml'
  - 'SCA scan interval: 2m'
  - Verify SCA results in Wazuh dashboard after next scan cycle.

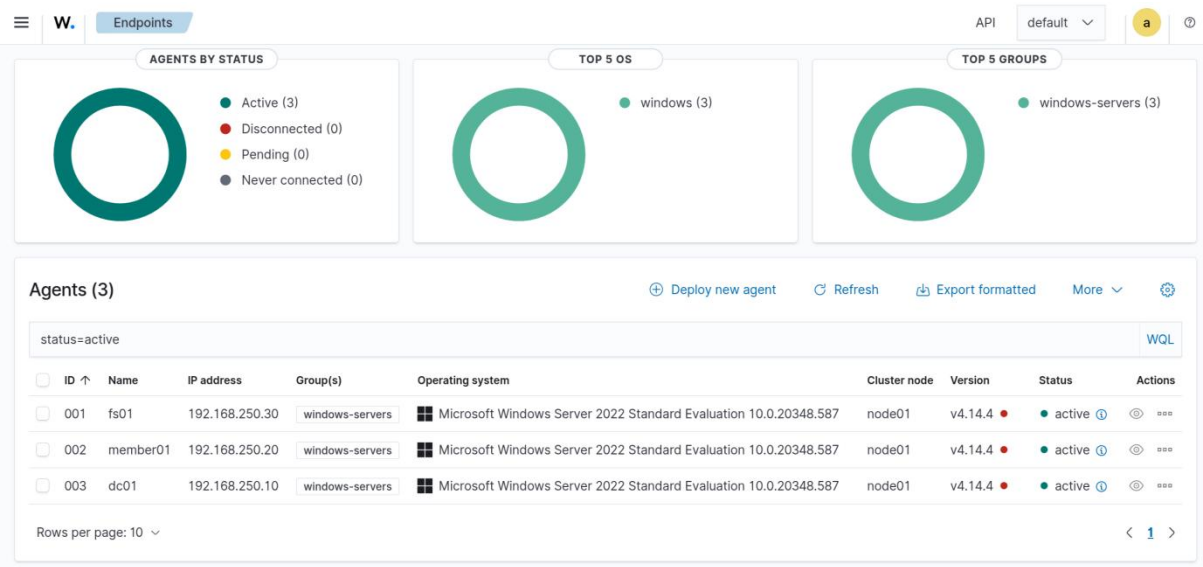
PLAY RECAP *****
dc01      : ok=19  changed=8  unreachable=0  failed=0  skipped=3  rescued=0  ignored=0
fs01      : ok=19  changed=8  unreachable=0  failed=0  skipped=3  rescued=0  ignored=0
log01     : ok=17  changed=5  unreachable=0  failed=0  skipped=3  rescued=0  ignored=0
member01  : ok=19  changed=8  unreachable=0  failed=0  skipped=3  rescued=0  ignored=0

o ansible on y main →
  
```

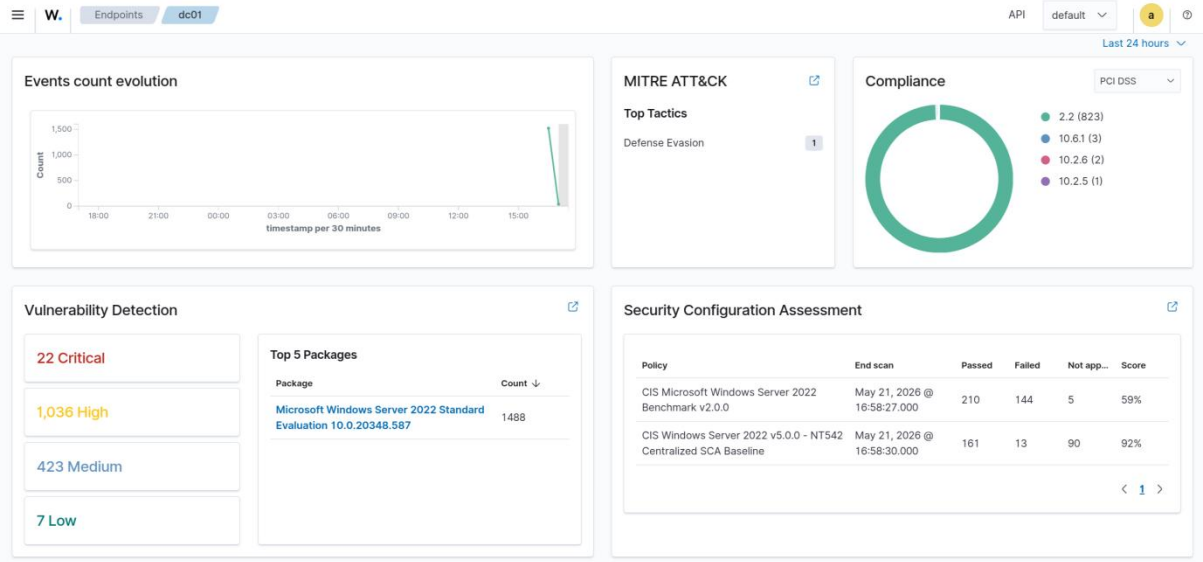
Hình 11. Kết quả triển khai Wazuh Manager và Wazuh Agent sử dụng Ansible



Hình 12. Giao diện chính của Wazuh



Hình 13. Giao diện giám sát tập trung



Hình 14. Giao diện giám sát đơn máy

Chương VI. TỔNG KẾT

6.1. Kết quả

6.1.1 Kết quả các cấu hình

6.1.1.1. Identity & Access Control

Nhóm cấu hình Identity & Access Control đã được triển khai tự động trên các máy dc01, member01, fs01 thông qua pipeline Ansible kết hợp PowerShell.

Kết quả post-audit cho thấy miền này đạt 36/53 tiêu chí Pass (68%), với 17 tiêu chí Fail. Theo từng nhóm con:

- Account Policies đạt 3/11 (27%); trong đó Password Policy đạt 3/7 (43%) và Account Lockout đạt 0/4 (0%).
- Nhóm Local Policies đạt 33/42 (79%); gồm User Rights đạt 31/38 (82%) và Security Options đạt 2/4 (50%).

Kết quả này cho thấy các thiết lập quyền người dùng và tùy chọn bảo mật cục bộ đã đạt mức tương đối tốt, trong khi các chính sách mật khẩu/khóa tài khoản vẫn là phần cần ưu tiên hoàn thiện ở các vòng tinh chỉnh tiếp theo.

CIS Post-Audit Report - Identity & Access Control (Full)				
Thời gian quét: 20/05/2026 23:04:59				
Hệ điều hành: Microsoft Windows Server 2022 Standard Evaluation				
Description	Tests		Scoring	
	Pass	Fail	Max	Percent
1 Account Policies	3	8	11.0	27%
1.1 Password Policy	3	4	7.0	43%
1.2 Account Lockout	0	4	4.0	0%
2 Local Policies	33	9	42.0	79%
2.2 User Rights	31	7	38.0	82%
2.3 Sec Options	2	2	4.0	50%
Total	36	17	53.0	68%

Hình 15. Kết quả post audit nhóm Identity và Access Control

6.1.1.2. Network Services Security

Nhóm cấu hình Network Services Security đã được triển khai tự động trên các máy dc01, member01, fs01 thông qua pipeline Ansible kết hợp PowerShell.

Kết quả post-audit cho thấy miền này đạt 83/87 tiêu chí Pass (95%), với 4 tiêu chí Fail. Theo từng nhóm con:

- Network Security & Access đạt 29/31 (94%); Windows Firewall đạt 21/23 (91%), trong đó Domain Profile đạt 7/7 (100%), Private Profile đạt 6/7 (86%), và Public Profile đạt 8/9 (89%).
- Nhóm Administrative Templates (Network) đạt 11/11 (100%).
- Nhóm Services, Printers & RDP đạt 22/22 (100%), gồm System Services 1/1 (100%), Printers 12/12 (100%), và Remote Desktop Services 9/9 (100%).

Kết quả này cho thấy các thiết lập bảo mật mạng cốt lõi đã đạt mức tuân thủ rất cao; các tiêu chí chưa đạt tập trung chủ yếu ở một số rule của Windows Firewall (Private/Public profile), là phần có thể ưu tiên tinh chỉnh trong các vòng remediation tiếp theo.

CIS Post-Audit Report - Windows Server 2022 Benchmark				
Thời gian quét: 20/05/2026 23:05:26				
Hệ điều hành: Microsoft Windows Server 2022 Standard Evaluation				
Description	Tests		Scoring	
	Pass	Fail	Max	Percent
1 Network Security & Access	29	2	31.0	94%
2.3 Security Options	29	2	31.0	94%
2 Windows Firewall	21	2	23.0	91%
9.1 Domain Profile	7	0	7.0	100%
9.2 Private Profile	6	1	7.0	86%
9.3 Public Profile	8	1	9.0	89%
3 Administrative Templates (Network)	11	0	11.0	100%
18.6 Network	11	0	11.0	100%
4 Services, Printers & RDP	22	0	22.0	100%
5 System Services	1	0	1.0	100%
18.7 Printers	12	0	12.0	100%
18.10 Remote Desktop Services	9	0	9.0	100%
Total	83	4	87.0	95%

Hình 16. Kết quả Post-Audit nhóm Network Services Security

6.1.1.3 Auditing và Monitoring

Nhóm cấu hình Auditing & Monitoring đã được triển khai tự động trên các máy dc01, member01, fs01 thông qua pipeline Ansible kết hợp PowerShell. Kết quả post-audit cho thấy miền này đạt 44/44 tiêu chí Pass (100%), 0 tiêu chí Fail.

Theo từng nhóm con:

- Local Policies đạt 2/2 (100%)
- Advanced Audit Policy đạt 34/34 (100%)
- Event Log Service đạt 8/8 (100%).

Kết quả này cho thấy các cấu hình ghi log và chính sách audit đã được áp dụng đầy đủ, tạo nền tảng tốt cho giám sát an ninh liên tục và truy vết sự kiện trong môi trường vận hành.

CIS Post-Audit Report - Auditing & Monitoring				
Thời gian quét: 20/05/2026 23:28:25 Hệ điều hành: Microsoft Windows Server 2022 Standard Evaluation				
Description	Tests		Scoring	
	Pass	Fail	Max	Percent
1 Local Policies	2	0	2.0	100%
1.1 Registry Settings	2	0	2.0	100%
2 Advanced Audit Policy	34	0	34.0	100%
2.2 Audit Policy Settings	34	0	34.0	100%
3 Event Log Service	8	0	8.0	100%
3.1 Registry Settings	8	0	8.0	100%
Total	44	0	44.0	100%

Hình 17. Kết quả Post-Audit nhóm Auditing và Monitoring

6.1.1.4. System Hardening & Antimalware

Nhóm cấu hình System Hardening & Antimalware đã được triển khai tự động trên các máy dc01, member01, fs01 thông qua pipeline Ansible kết hợp PowerShell. Kết quả post-audit cho thấy miền này đạt 84/102 tiêu chí Pass (82%), với 18 tiêu chí Fail. Theo các nhóm cấu hình chính:

- Microsoft Defender Antivirus đạt 17/25 (68%)

- MS Security Guide đạt 7/8 (88%)
- Đa số nhóm còn lại đạt 100% (MSS Legacy, UAC, Device Guard/VBS, LSA, AutoPlay Policies, ELAM, SmartScreen, Windows PowerShell, Desktop App Installer, File Explorer, Windows Installer, Attachment Manager, RSS Feeds, Device Installation, Kernel DMA Protection, Credentials Delegation, SAM).
- Điểm chưa đạt tập trung lớn ở Windows LAPS với 0/9 (0%).

Kết quả này cho thấy mức độ hardening hệ thống đã tương đối cao và đồng đều ở nhiều miền kiểm soát; phần cần ưu tiên hoàn thiện ở vòng tiếp theo là các cấu hình LAPS và một số thiết lập sâu của Defender Antivirus để nâng điểm tuân thủ tổng thể.

CIS Post-Audit Report - System Hardening & Antimalware

Thời gian quét: 20/05/2026 22:20:52
 Hệ điều hành: Microsoft Windows Server 2022 Standard Evaluation

Description	Tests		Scoring	
	Pass	Fail	Max	Percent
1 Microsoft Defender Antivirus	17	8	25.0	68%
2 MS Security Guide	7	1	8.0	88%
3 MSS (Legacy)	12	0	12.0	100%
4 User Account Control (UAC)	8	0	8.0	100%
5 Device Guard / VBS	7	0	7.0	100%
6 Local Security Authority	2	0	2.0	100%
7 AutoPlay Policies	3	0	3.0	100%
8 Early Launch Antimalware	1	0	1.0	100%
9 Windows Defender SmartScreen	2	0	2.0	100%
10 Windows PowerShell	2	0	2.0	100%
11 Desktop App Installer	7	0	7.0	100%
12 File Explorer	4	0	4.0	100%
13 Windows Installer	3	0	3.0	100%
14 Attachment Manager	2	0	2.0	100%
15 RSS Feeds	2	0	2.0	100%
16 Device Installation	1	0	1.0	100%
17 Kernel DMA Protection	1	0	1.0	100%
18 Windows LAPS	0	9	9.0	0%
19 Credentials Delegation	2	0	2.0	100%
20 Security Account Manager (SAM)	1	0	1.0	100%
Total	84	18	102.0	82%

Hình 18. Kết quả post-audit System Hardening & Antimalware

6.1.2 Kết quả đánh giá bổ sung bằng HardeningKitty

Kết quả từ HardeningKitty cho phép nhóm đánh giá nhanh mức độ cải thiện cấu hình bảo mật sau khi triển khai pipeline hardening. Báo cáo summary phản ánh các chỉ số quan trọng như điểm tổng quát của hệ thống (score), tổng số lượng kiểm tra, số lượng mục đạt (passed) và số lượng findings theo từng mức độ nghiêm trọng (low, medium, high).

Trên máy chủ dc01, HardeningKitty ghi nhận hệ thống đạt score 4.21, với tổng cộng 328 kiểm tra, trong đó có 169 mục đạt, 6 finding mức Low, 153 finding mức Medium và 0 finding mức High, như thể hiện ở Hình 5.1.

NT542.Q22-Project > pipeline > reports > dc01 > hardeningkitty-validation > HardeningKitty-dc01-summary.csv									
	host	finding_list	score	total_checks	passed	low	medium	high	
1	dc01	finding_list_msft_security_baseline_windows_server_2022_21h2_dc_machine.csv	4.21	328	169	6	153	0	
2									

Hình 19. Kết quả kiểm định HardeningKitty trên máy chủ dc01

Tương tự, trên máy chủ member01, công cụ ghi nhận score 4.21, với 328 kiểm tra, 170 mục đạt, 5 finding mức Low, 153 finding mức Medium và 0 finding mức High, như thể hiện ở Hình 5.2.

NT542.Q22-Project > pipeline > reports > member01 > hardeningkitty-validation > HardeningKitty-member01-summary.csv									
	host	finding_list	score	total_checks	passed	low	medium	high	
1	member01	finding_list_msft_security_baseline_windows_server_2022_21h2_member_machine.csv	4.21	328	170	5	153	0	
2									

Hình 20. Kết quả kiểm định HardeningKitty trên máy chủ member01

Bên cạnh báo cáo summary, HardeningKitty còn xuất file CSV chi tiết phản ánh từng rule CIS, giá trị hiện tại, giá trị khuyến nghị và trạng thái pass/fail. Điều này giúp nhóm dễ dàng đối chiếu giữa trước và sau khi triển khai pipeline, đồng thời xác định chính xác các mục đã được khắc phục thành công và các mục vẫn cần tiếp tục xử lý.

NT542.Q22-Project > pipeline > reports > member01 > hardeningkitty-validation > HardeningKitty-member01.csv										
	ID	Category	Name	Severity	Result	Recommended	TestResult	SeverityFinding	DefaultValue	Filter
1	10000	Account Policies	Account lockout duration	Passed	15	15	Passed	Low	False	
2	10001	Account Policies	Account lockout threshold	Passed	5	10	Passed	Low	False	
3	10002	Account Policies	Reset account lockout counter	Passed	15	15	Passed	Low	False	
4	10100	Account Policies	Length of password history maintained	Passed	24	24	Passed	Low	False	
5	10101	Account Policies	Minimum password length	Passed	14	14	Passed	Medium	False	
6	10102	Account Policies	Password must meet complexity requirements	Passed	1	1	Passed	Medium	False	
7	10103	Account Policies	Store passwords using reversible encryption	Passed	0	0	Passed	High	False	
8	10200	Security Options	Accounts: Limit local account use of blank passwords to console logon only	Passed	1	1	Passed	Medium	False	
9	10201	Security Options	Audit: Force audit policy subcategory settings to override audit policy category settings	Passed	1	1	Passed	Low	True	
10	10202	Security Options	Domain member: Digitally encrypt or sign secure channel data (always)	Passed	1	1	Passed	Medium	False	
11	10203	Security Options	Domain member: Digitally encrypt secure channel data (when possible)	Passed	1	1	Passed	Medium	False	
12	10204	Security Options	Domain member: Digitally sign	Passed	1	1	Passed	Medium	False	

Hình 21. Trích đoạn file CSV chi tiết của HardeningKitty trên máy chủ member01

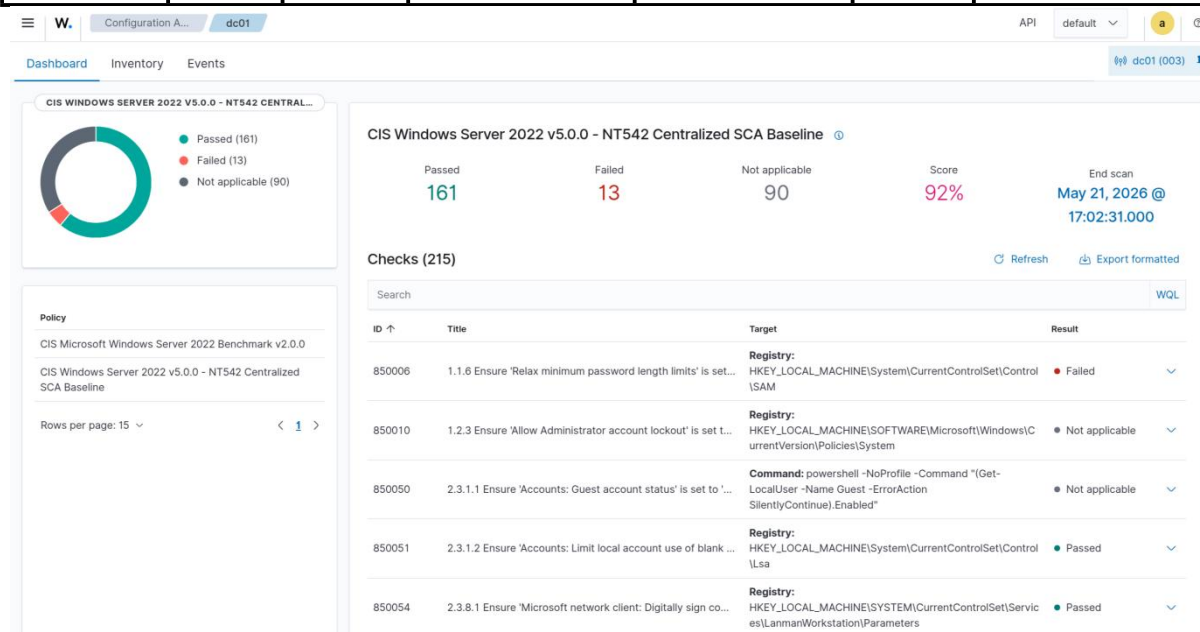
6.1.3. Kết quả giám sát với Wazuh

Sau khi triển khai pipeline hardening kết hợp Ansible và Wazuh, hệ thống đã ghi nhận được trạng thái tuân thủ cấu hình bảo mật theo chuẩn CIS trực tiếp trên các máy Windows Server.

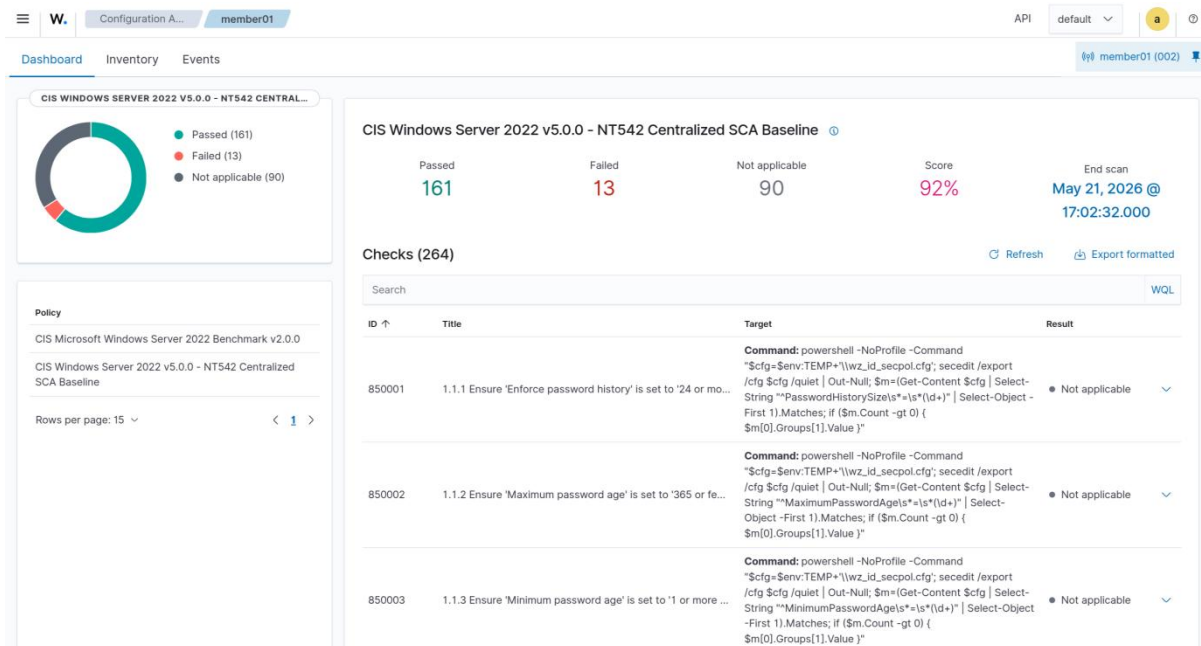
Sau khi triển khai pipeline và gán policy CIS Windows Server 2022 v5.0.0 - NT542 Centralized SCA Baseline trên Wazuh, cả 3 máy dc01, member01, fs01 đều đã được quét thành công với cùng một bộ kiểm tra.

Kết quả chi tiết theo từng máy:

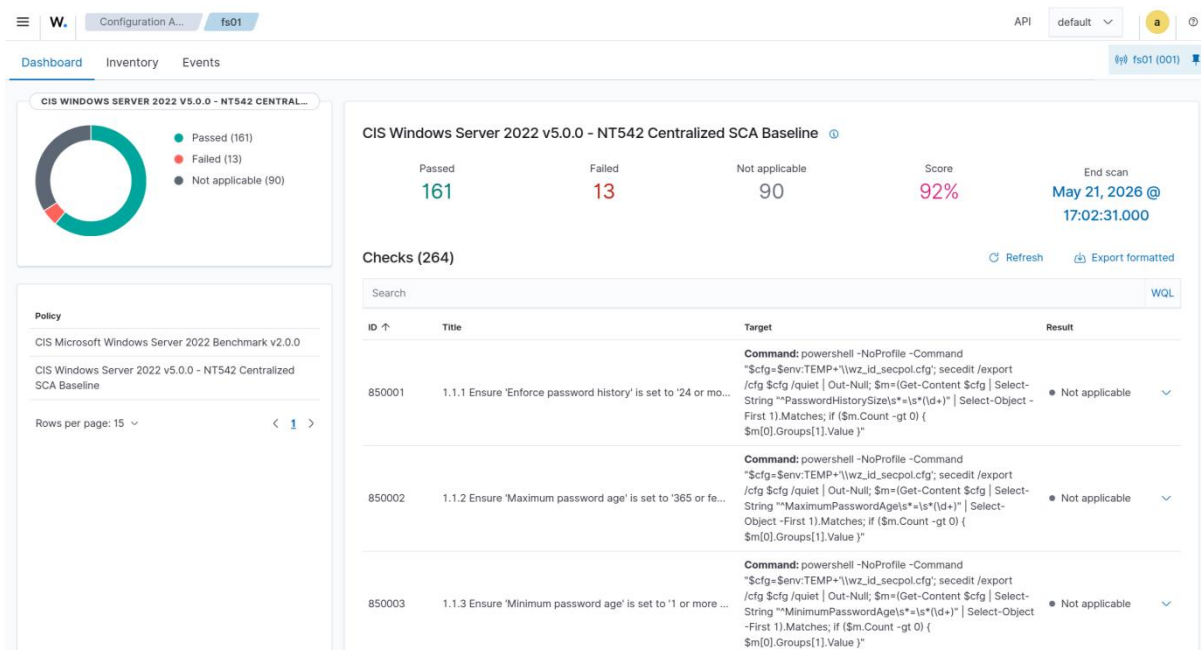
Máy chủ	Passed	Failed	Not applicable	Tổng checks	Score	End scan
dc01	161	13	90	264	92%	May 21, 2026 @ 16:58:30.000
member01	161	13	90	264	92%	May 21, 2026 @ 17:02:32.000
fs01	161	13	90	264	92%	May 21, 2026 @ 17:02:31.000



Hình 22. Kết quả giám sát trên máy dc01



Hình 23. Kết quả giám sát trên máy member01



Hình 24. Kết quả giám sát trên máy fs01

6.2. Hạn chế và hướng phát triển

6.2.1 Hạn chế hiện tại

Mức tuân thủ chưa tối đa, vẫn còn một số mục Failed cần xử lý theo ưu tiên rủi ro.

WinRM còn nhạy cảm khi đổi tài khoản/prefix hoặc gặp lockout, có thể làm gián đoạn pipeline.

Policy mặc định Wazuh (CIS v2.0.0) chưa khớp hoàn toàn baseline CIS v5.0.0 của đề tài.

Một số tình huống vẫn cần thao tác tay (recreate VM, đồng bộ lại trạng thái agent/service).

6.2.2 Hướng phát triển

Duy trì và mở rộng custom SCA policy bám sát CIS v5.0.0.

Bổ sung cơ chế credential-safe cho WinRM (fallback an toàn, giảm lockout).

Chuẩn hóa pipeline theo GitOps/CI: lint, syntax-check, dry-run, test tự động.

Xây dashboard theo dõi xu hướng tuân thủ, cảnh báo drift theo mức độ nghiêm trọng.

Mở rộng thêm role máy chủ và tích hợp thêm lớp kiểm chứng lỗ hổng OS/service.

6.3. Kết luận

Đề tài đã chứng minh tính khả thi của mô hình hardening tự động cho Windows Server 2022 trong môi trường lab: dùng Terraform để chuẩn hóa hạ tầng, Ansible để điều phối thực thi tập trung, PowerShell để hiện thực chi tiết kiểm soát CIS, và Wazuh để giám sát liên tục sau triển khai.

Giá trị thực tiễn lớn nhất là chuyển quy trình hardening từ “làm một lần, phụ thuộc thao tác tay” sang “vận hành theo vòng đời, có thể kiểm chứng và cải tiến liên tục”. Dù còn hạn chế về độ phủ tuân thủ và độ ổn định vận hành, kiến trúc hiện tại đã tạo nền tảng tốt để nâng cấp thành hệ thống quản trị cấu hình bảo mật bán tự động/tự động ở quy mô lớn hơn.

BẢNG PHÂN CÔNG

Thành viên	Công việc	Mức độ hoàn thành
Lê Trung Kiên (23520797)	+ Module 2 (Network and Services Secutiry) + Viết báo cáo 2.1, 2.2, 2.3, 3.3 + Code khung audit + remediation (script) + Làm slide	100%
Nguyễn Tiến Phát (23521147)	+ Module 4 (System Hardening and Antimalware) + Viết báo cáo Chương 5, 6.1, 3.4 + Tích hợp tool thứ 3(Hardening Kitty) + Workflow Ansible + Làm slide + Video demo	100%
Nguyễn Thị Như Trang (23521628)	+ Module 1 (Identity and Access Control) + Kiến trúc hệ thống + Viết báo cáo Chương 1, 2.4, 3.1 + Làm slide	100%
Trần Nguyễn Phú Thuận (23521554)	+ Module 3 (Audit and Monitoring) + Viết báo cáo phần Lời cảm ơn, 3.3, 6.2, 6.3 + Làm slide	100%

NGUỒN THAM KHẢO

- [1] V. C. Immunity, “CIS Benchmarks: Giải pháp bảo mật toàn diện cho mọi doanh nghiệp, tổ chức và cá nhân.” Accessed: May 10, 2026. [Online]. Available: <https://sec.vnpt.vn/2024/03/cis-benchmarks-giai-phap-bao-mat-toan-dien-cho-moi-doanh-nghiep-to-chuc-va-ca-nhan>
- [2] “Windows Server 2022 - Wikipedia.” Accessed: May 10, 2026. [Online]. Available: https://en.wikipedia.org/wiki/Windows_Server_2022
- [3] Wazuh, “Overview,” Wazuh. Accessed: May 10, 2026. [Online]. Available: <https://wazuh.com/platform/overview/>
- [4] sdwheeler, “Introducing the Windows PowerShell ISE - PowerShell.” Accessed: May 10, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/powershell/scripting/windows-powershell/ise/introducing-the-windows-powershell-ise?view=powershell-7.6>
- [5] “scipag/HardeningKitty,” DeepWiki. Accessed: May 10, 2026. [Online]. Available: <https://deepwiki.com/scipag/HardeningKitty>
- [6] “Getting Started with Ansible A Beginners Guide.” Accessed: May 10, 2026. [Online]. Available: https://learnansible.dev/article/Getting_Started_with_Ansible_A_Beginners_Guide.html